

RELATÓRIO INDIVIDUAL PRELIMINAR

**RIOPREVIDENCIA - Fundo Único de Previdência Social do
Estado do Rio de Janeiro - RIOPREVIDENCIA**

1. Introdução

Este relatório apresenta os resultados preliminares da organização **RIOPREVIDENCIA** relativos à Fiscalização TCE-RJ nº 18/2026, realizada pelo TCE-RJ entre fevereiro e junho de 2026 para avaliar o grau de adoção de práticas de governança e gestão de tecnologia da informação e comunicação pelas organizações jurisdicionadas.

O trabalho abrangeu órgãos e entidades de todos os poderes da Administração Pública Estadual e um conjunto de prefeituras municipais.

2. iGovTI 2026

A avaliação das organizações jurisdicionadas baseia-se no método de autoavaliação de controles (*Control Self-Assessment* – CSA), operacionalizado mediante questionário eletrônico. A ferramenta permitiu aos gestores declarar o nível de adoção das práticas de tecnologia da informação avaliadas e encaminhar a documentação probatória correspondente. As evidências anexadas e as justificativas apresentadas foram submetidas à análise de consistência por esta Equipe de Auditoria, servindo de subsídio para eventuais ajustes na pontuação declarada e para a identificação de inconformidades ou achados de auditoria.

O questionário do iGovTI 2026 foi estruturado com o objetivo de diagnosticar aspectos essenciais de governança e gestão de TIC, abrangendo segurança da informação, gestão de riscos, continuidade de negócios, serviços de tecnologia, contratações de TIC, estrutura e força de trabalho, desenvolvimento de soluções, gestão de projetos e temas emergentes, a exemplo do uso de inteligência artificial. Para além do diagnóstico situacional de cada organização, o instrumento serve como referencial metodológico para futuras ações de melhoria de gestão.

O iGovTI 2026 constitui um índice composto, mensurado em uma escala de 0 a 1. A quantificação do índice inicia-se com a conversão das respostas categóricas declaradas em coeficientes numéricos, conforme os critérios de valoração estabelecidos na Tabela 1.

Tabela 1 - Critérios de valoração das respostas qualitativas do questionário iGovTI 2026

Categoria de Resposta Declarada	Coefficiente Numérico
Não adota	0,00
Há decisão formal ou plano aprovado para adotá-lo	0,05
Adota em menor parte	0,15
Adota parcialmente	0,50

Categoria de Resposta Declarada	Coefficiente Numérico
Adota em maior parte ou totalmente	1,00

(Fonte: elaboração própria)

Nas questões que admitem itens de detalhamento, a pontuação da questão principal sofre deduções proporcionais à quantidade de itens não atendidos pela organização. Subsequentemente, os valores são consolidados por meio de agregação ponderada em uma estrutura hierárquica. O índice final é composto por dois blocos principais, conforme detalhado na Figura 1: **Governança de TIC (peso de 47,8%)**, formado por 4 questões de agregação direta; **Gestão de TIC (iGestTI) (peso de 52,2%)**, estruturado em 6 dimensões operacionais que consolidam 20 questões principais ponderadas.

Figura 1 - Composição do iGovTI 2026



(Fonte: elaboração própria)

Com base na pontuação consolidada do iGovTI 2026, a organização é classificada em um de quatro níveis de maturidade, cujos intervalos de pontuação estão definidos na Tabela 2 e representados graficamente na parte inferior da Figura 1.

Tabela 2 - Intervalos de pontuação para enquadramento nos níveis de maturidade

Nível de Maturidade	Intervalo do Índice (iGovTI)
Inexpressivo	$0,00 \leq \text{iGovTI} < 0,15$
Iniciando	$0,15 \leq \text{iGovTI} < 0,40$

Nível de Maturidade	Intervalo do Índice (iGovTI)
Intermediário	$0,40 \leq \text{iGovTI} < 0,70$
Aprimorado	$0,70 \leq \text{iGovTI} \leq 1,00$

(Fonte: elaboração própria)

2.1. Cenário Geral

A análise consolidada apresentada nesta seção fundamenta-se nos resultados calculados para as 114 organizações que integram o universo amostral da fiscalização. A análise visa contextualizar o resultado individual da organização **RIOPREVIDENCIA**, identificar padrões de maturidade, assimetrias entre governança e gestão e capacidades desenvolvidas no conjunto avaliado.

A distribuição por nível de maturidade, apresentada na Figura 2, evidencia concentração nos estágios iniciais. Das 114 organizações, 61 (53,5%) foram classificadas no nível **Inexpressivo** e 39 (34,2%) no nível **Iniciando**. Assim, 100 organizações (87,7%) obtiveram resultado inferior a 0,40. Somente 10 organizações (8,8%) alcançaram o nível **Intermediário** e 4 (3,5%) o nível **Aprimorado**.

Figura 2 - Distribuição das organizações por nível de maturidade do iGovTI 2026



(Fonte: elaboração própria)

O iGovTI apresentou média de 0,187 e mediana de 0,135. O primeiro quartil foi 0,066 e o terceiro quartil, 0,235, o que evidencia a concentração de 50% das organizações avaliadas nesse intervalo, bem como a permanência de pelo menos 75% das entidades

abaixo do nível Intermediário. A divergência positiva entre a média e a mediana, combinada com o valor máximo de 0,777 e com apenas 4 organizações no nível Aprimorado, caracteriza uma distribuição com assimetria à direita (positiva): um grupo reduzido de resultados elevados desloca a média para cima, sem alterar o quadro predominante de baixa maturidade. 5 organizações apresentaram valor igual a zero no índice calculado.

A distribuição contínua da Figura 3 complementa a classificação por faixas e permite observar a concentração dos resultados, os limites de maturidade e a distância entre a mediana e os valores mais elevados.

Figura 3 - Distribuição contínua dos resultados do iGovTI 2026



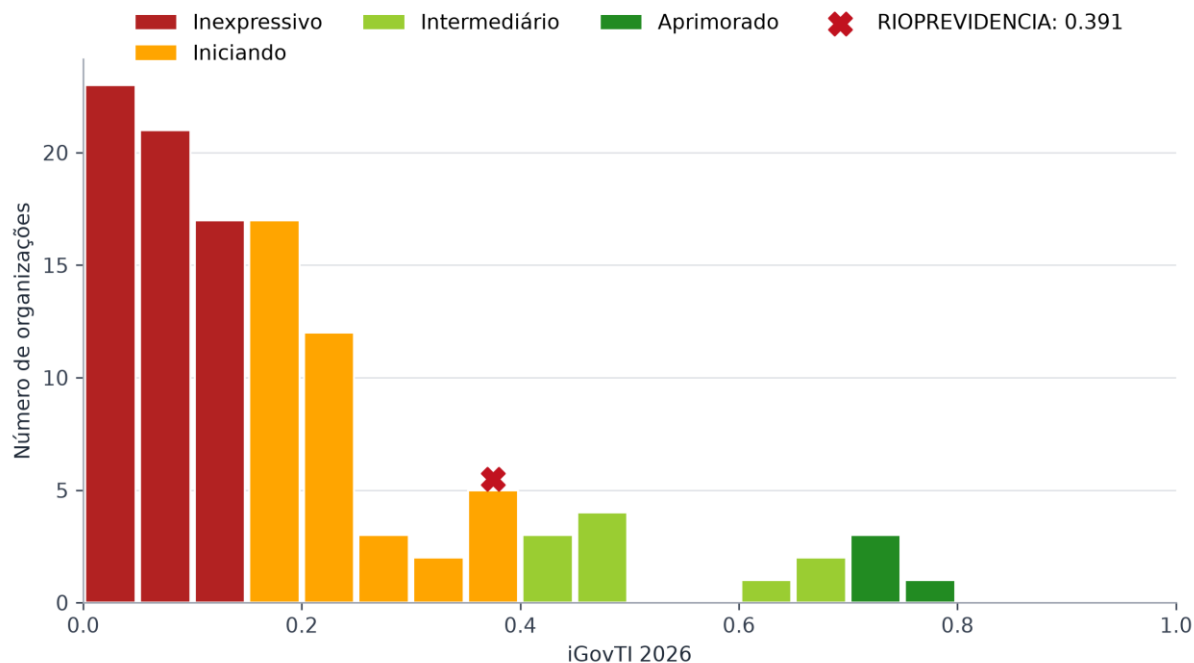
(Fonte: elaboração própria)

A posição específica da organização **RIOPREVIDENCIA** nessa distribuição pode ser observada na Figura 4. Diferenças marginais de pontuação entre organizações adjacentes no ranking devem ser interpretadas com cautela analítica, visto que o modelo matemático de composição do índice não pressupõe estimativa de erro amostral e que os resultados estão sujeitos à qualidade e à fidedignidade declaratória do jurisdicionado.

2.2. Cenário atual - RIOPREVIDENCIA

Apresentado o panorama geral do universo fiscalizado, esta subseção detalha o desempenho específico da organização jurisdicionada. A organização **RIOPREVIDENCIA** obteve o **valor 0,3907 para o iGovTI 2026**, correspondente ao nível **Iniciando** de maturidade.

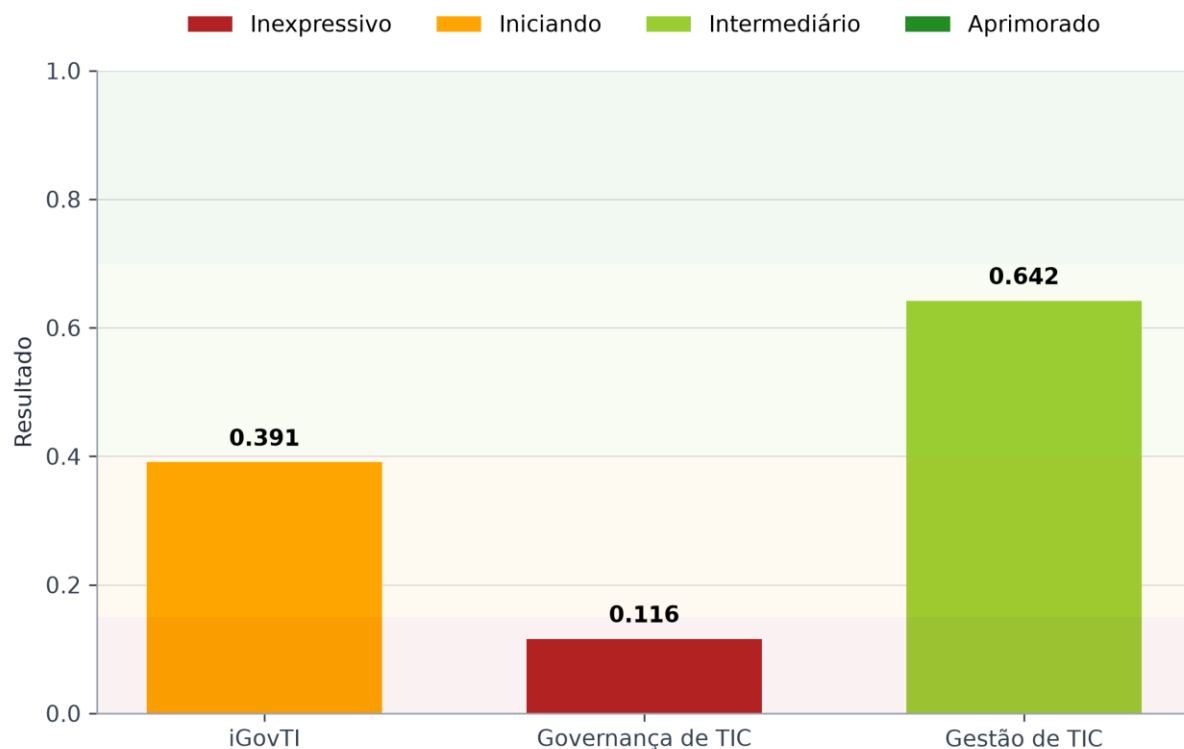
Figura 4 - Distribuição dos resultados do iGovTI 2026 e posição da organização RIOPREVIDENCIA



(Fonte: elaboração própria)

A Figura 5 apresenta a composição do resultado da organização **RIOPREVIDENCIA** entre governança e gestão de TIC.

Figura 5 - Resultado da organização RIOPREVIDENCIA por componentes do iGovTI 2026



(Fonte: elaboração própria)

Tabela 3 - Resultado sintético do iGovTI 2026 da organização RIOPREVIDENCIA

Componente	Peso no iGovTI 2026	Valor
Governança de TIC	0,4777	0,1160
Gestão de TIC	0,5223	0,6420
iGovTI 2026	1,0000	0,3907

(Fonte: elaboração própria)

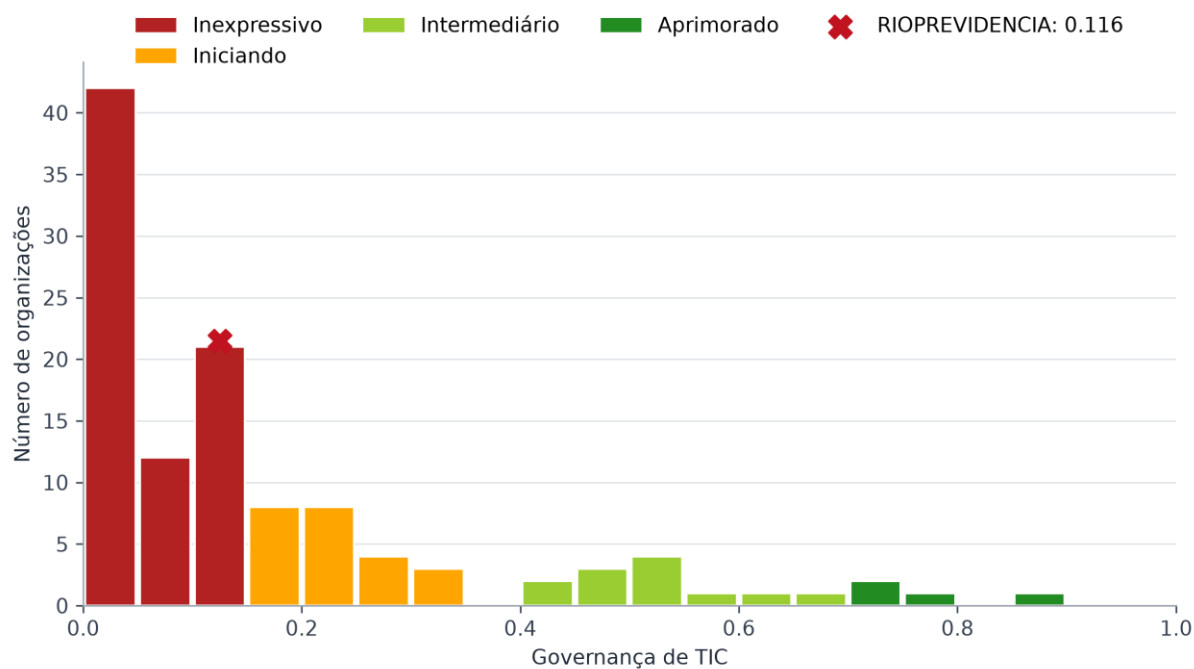
2.2.1. Governança de TIC

A governança de TIC avalia a capacidade da alta administração de orientar, dirigir, monitorar e controlar o uso da tecnologia da informação, de modo alinhado aos objetivos institucionais, aos riscos relevantes e às necessidades das áreas finalísticas e administrativas.

No iGovTI 2026, a dimensão de governança consolida práticas relacionadas ao modelo de gestão de TIC, à atuação de comitês ou instâncias equivalentes, no monitoramento do desempenho, à participação da alta administração e ao alinhamento entre decisões de TIC, estratégia organizacional, orçamento, riscos e valor público.

A organização **RIOPREVIDENCIA** obteve o **valor 0,1160 no componente Governança de TIC**.

Figura 6 - Resultado do componente Governança de TIC da organização RIOPREVIDENCIA



(Fonte: elaboração própria)

2.2.2. Gestão de TIC

A gestão de TIC avalia a capacidade da organização de planejar, executar, monitorar e aperfeiçoar processos, serviços, controles, recursos e contratações de tecnologia da informação, de forma compatível com suas necessidades institucionais.

No iGovTI 2026, o componente **Gestão de TIC (iGestTI)** consolida seis dimensões operacionais: planejamento de TIC, gestão de serviços de TIC, gestão de riscos de TI e segurança da informação, estrutura de segurança da informação, processos de segurança da informação e gestão de soluções de TIC.

A organização **RIOPREVIDENCIA** obteve o **valor 0,6420 no componente Gestão de TIC**.

Figura 7 - Resultado do componente Gestão de TIC da organização RIOPREVIDENCIA

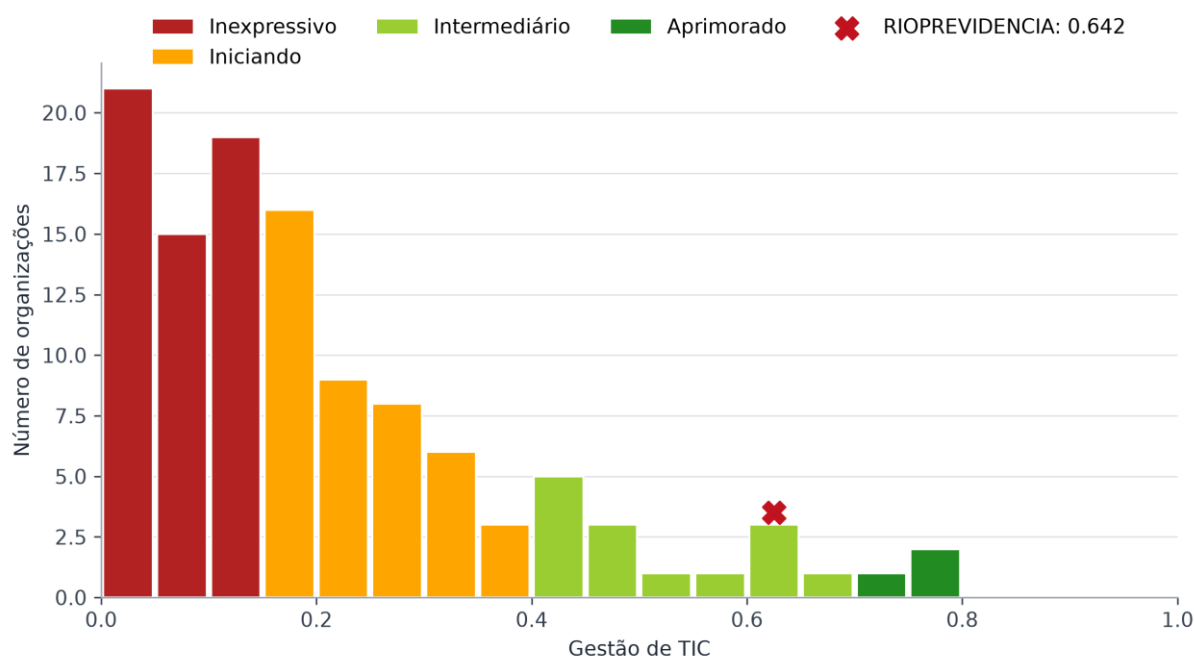


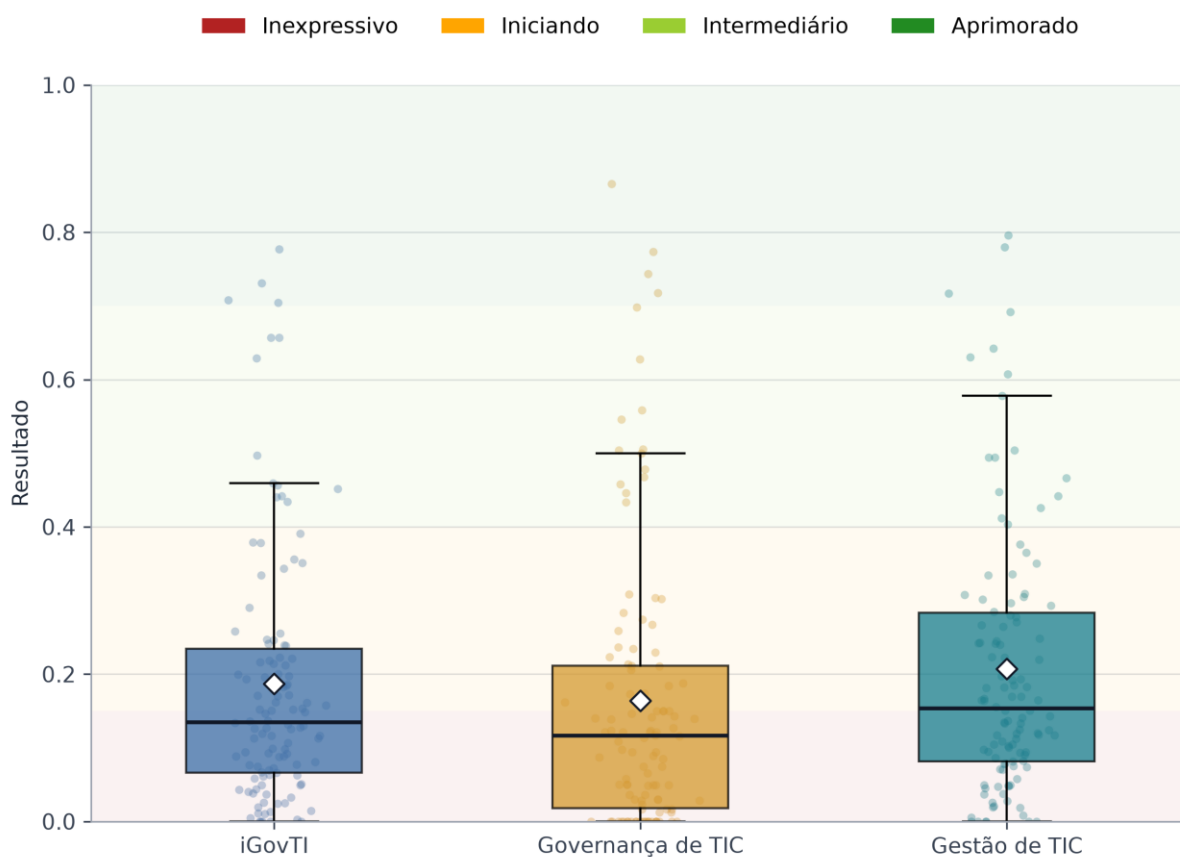
Tabela 4 - Estatísticas descritivas do iGovTI 2026 e de seus componentes principais

Indicador	1º		3º		Organizações com valor	Valor
	Média	quartil	Mediana	quartil	>= 0,40	RIOPREVIDENCIA
iGovTI	0,187	0,066	0,135	0,235	14 (12,3%)	0,3907
Governança de TIC	0,164	0,018	0,117	0,211	16 (14,0%)	0,1160
Gestão de TIC	0,208	0,082	0,153	0,283	17 (14,9%)	0,6420

(Fonte: elaboração própria)

A Figura 8 permite comparar a dispersão dos três indicadores. O resultado em Gestão de TIC superou o de Governança de TIC em 76 organizações (66,7%); o movimento inverso ocorreu em 33 (28,9%); e houve igualdade em 5 (4,4%). O padrão indica que, para a maior parte das organizações, as capacidades operacionais de gestão se situaram em patamar superior ao dos mecanismos de direção, monitoramento e controle exercidos pela alta administração. Essa diferença, contudo, não elimina a baixa maturidade da gestão: 97 organizações (85,1%) também obtiveram resultado em Gestão de TIC inferior a 0,40.

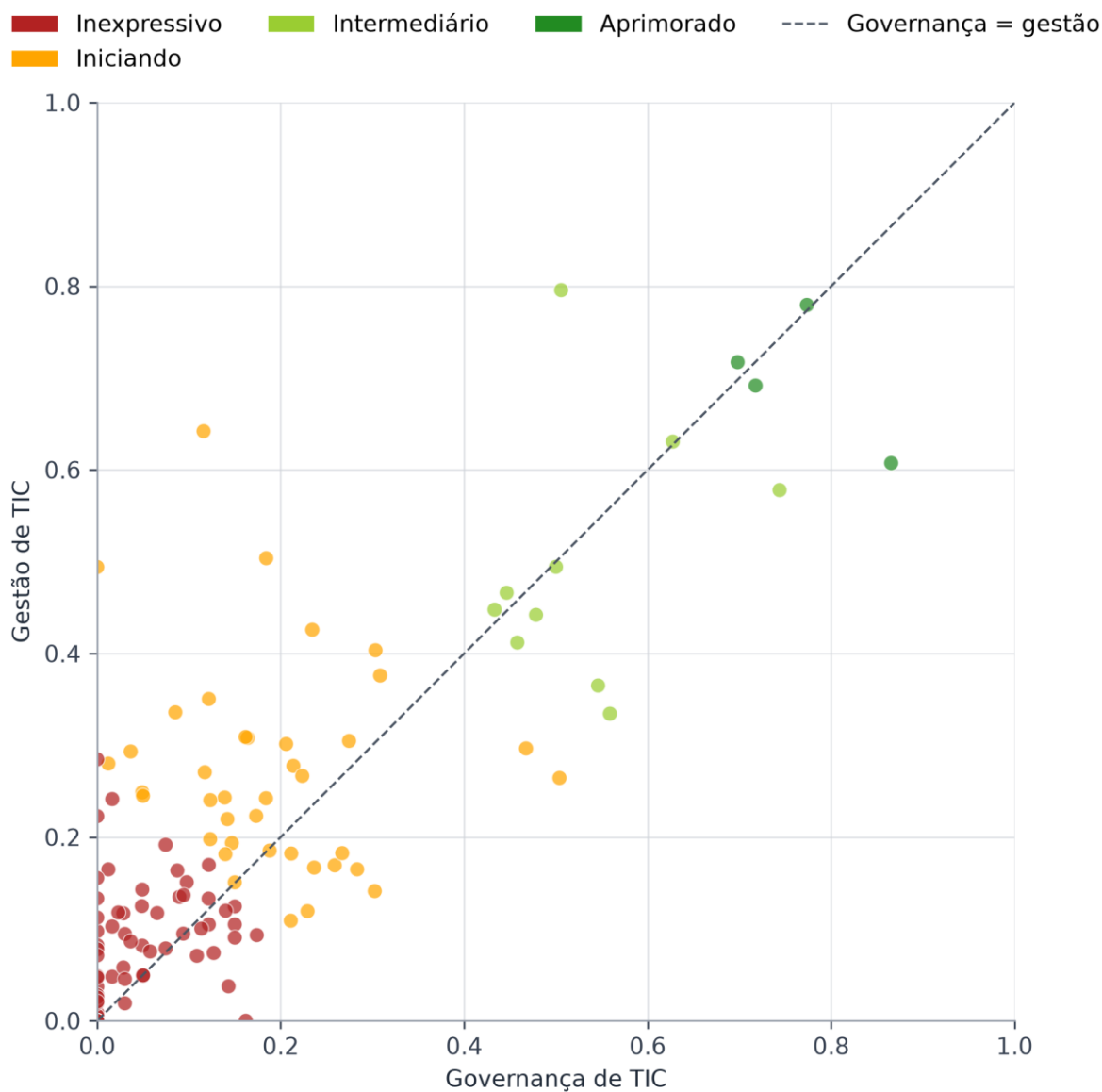
Figura 8 - Distribuição do iGovTI 2026 e dos componentes Governança de TIC e Gestão de TIC



(Fonte: elaboração própria)

A Figura 9 mostra a posição simultânea das organizações nos dois componentes. Pontos abaixo da diagonal representam resultado de gestão superior ao de governança; pontos acima da diagonal representam a situação inversa.

Figura 9 - Relação entre os resultados de governança e gestão de TIC



(Fonte: elaboração própria)

No caso da organização **RIOPREVIDENCIA**, o resultado em Governança de TIC ficou abaixo do resultado em Gestão de TIC. Esse perfil indica oportunidade de fortalecer os mecanismos pelos quais a alta administração direciona, monitora e avalia a TIC, especialmente quanto à definição de responsabilidades, objetivos, indicadores, prioridades, riscos e acompanhamento de resultados. A leitura deve ser aprofundada à luz das evidências e dos achados relacionados à governança.

2.4. Dimensões da gestão de TIC

A decomposição da Gestão de TIC revela diferenças relevantes entre as seis dimensões avaliadas. Conforme a Tabela 5, **Planejamento de TIC** apresentou a maior média (0,293) e a maior mediana (0,157). A dimensão com maior média também figurou como a de maior resultado em 50 organizações (43,9%), considerados os empates. Esse padrão indica que algumas capacidades se encontram mais disseminadas do que outras no conjunto fiscalizado.

Tabela 5 - Estatísticas descritivas das dimensões de Gestão de TIC

Dimensão	Média	Mediana	Resultados iguais a zero	Organizações com valor inferior a 0,40	Valor RIOPREVIDENCIA
Planejamento de TIC	0,293	0,157	21 (18,4%)	80 (70,2%)	0,8308
Gestão de Serviços de TIC	0,143	0,083	20 (17,5%)	102 (89,5%)	0,3521
Gestão de Riscos de TI e Segurança da Informação	0,168	0,097	32 (28,1%)	97 (85,1%)	0,5352
Estrutura de Segurança da Informação	0,260	0,137	25 (21,9%)	83 (72,8%)	0,8143
Processos de Segurança da Informação	0,202	0,144	10 (8,8%)	95 (83,3%)	0,5665
Gestão de Soluções de TIC	0,196	0,150	26 (22,8%)	101 (88,6%)	0,8236

(Fonte: elaboração própria)

A distribuição completa das seis dimensões é apresentada na Figura 10, incluindo medianas, intervalos interquartis e médias.

Figura 10 - Distribuição dos resultados das seis dimensões de Gestão de TIC



(Fonte: elaboração própria)

A Figura 11 explicita a composição de cada dimensão por nível de maturidade e permite verificar em quais capacidades se concentram as organizações nos estágios iniciais.

Figura 11 - Distribuição dos níveis de maturidade das organizações nas dimensões de Gestão de TIC



(Fonte: elaboração própria)

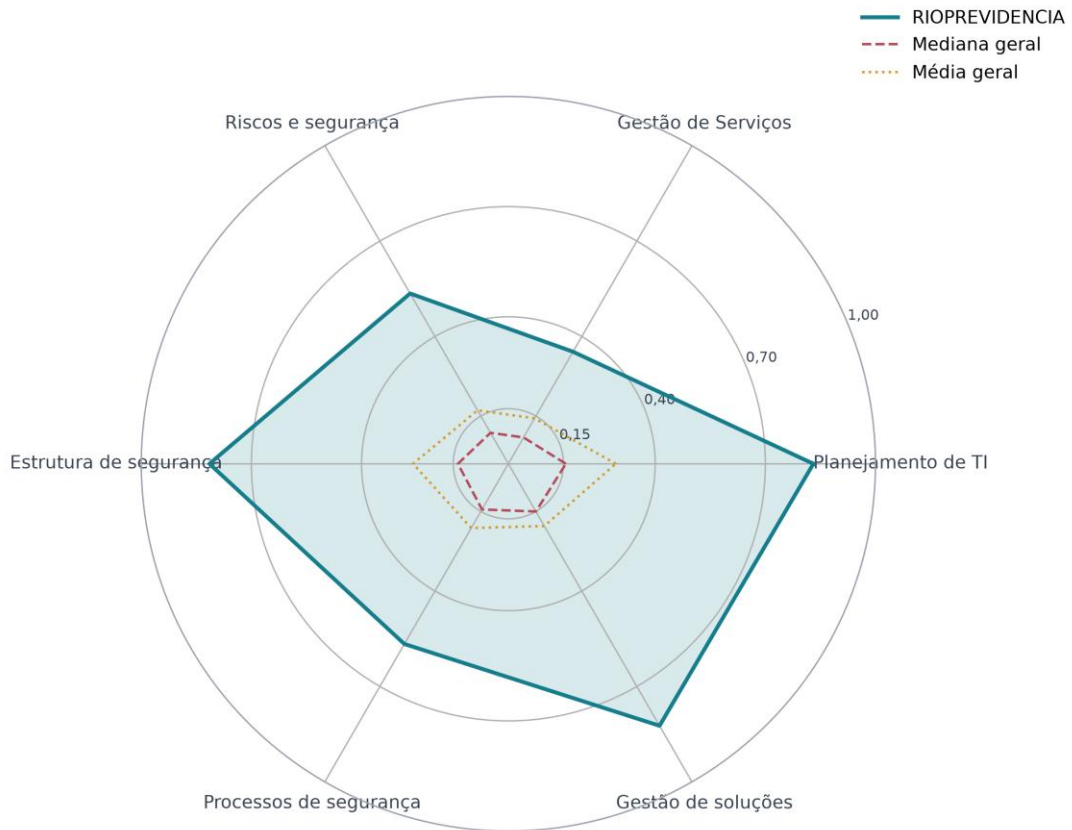
As menores médias foram observadas em **Gestão de serviços de TIC** (0,143) e **Riscos de TI e de segurança da informação** (0,168). A primeira registrou valor inferior a 0,40 em 102 organizações (89,5%) e apareceu entre as dimensões de menor resultado de 37 organizações (32,5%), considerados os empates. Para a segunda, esses quantitativos foram, respectivamente, 97 (85,1%) e 39 (34,2%). O quadro indica que a formalização do planejamento, quando existente, frequentemente não é acompanhada, na mesma intensidade, pelas demais capacidades operacionais e de segurança.

A dimensão Estrutura de Segurança da Informação apresentou média de 0,260 e mediana de 0,137. Essa diferença, associada à ampla dispersão observada na Figura 10, evidencia heterogeneidade: um grupo de organizações possui estruturas de segurança mais consolidadas, enquanto parcela expressiva permanece próxima dos níveis inferiores. A dimensão Processos de Segurança da Informação mostrou mediana superior à de Estrutura de Segurança da Informação, mas 83,3% das organizações ainda permaneceram abaixo de 0,40, o que recomenda examinar separadamente a existência da estrutura formal e a execução contínua dos processos de segurança.

2.5. Leitura integrada do resultado individual

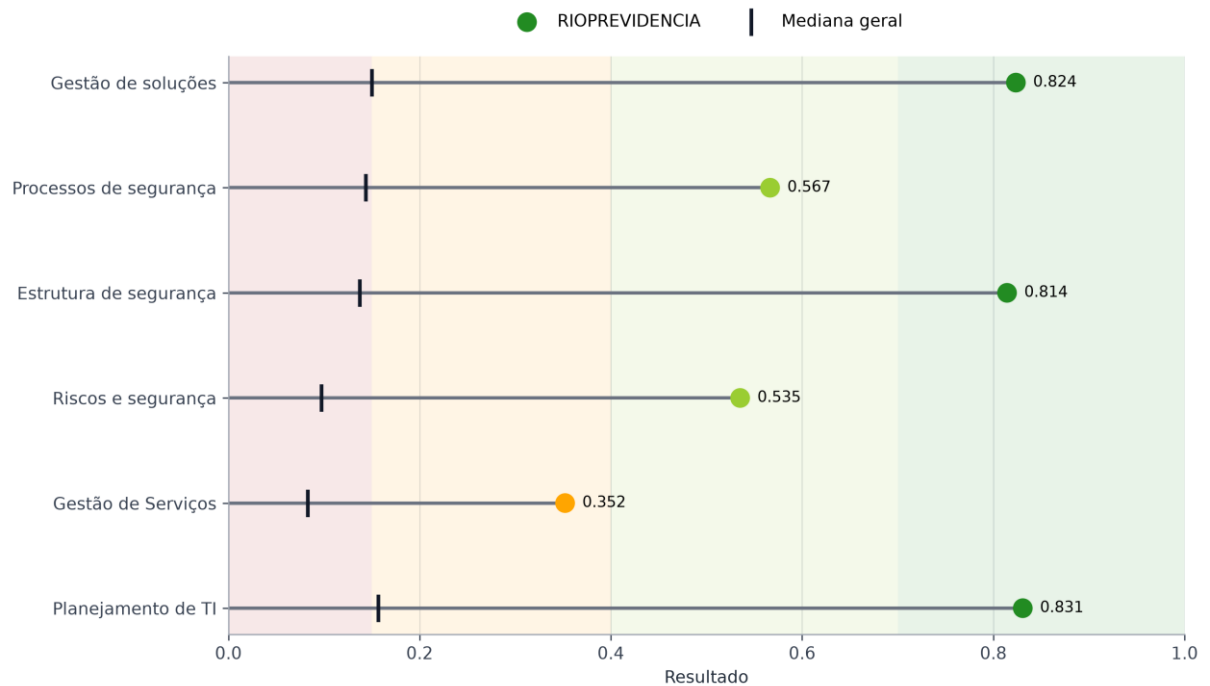
A Figura 12 apresenta o perfil da organização **RIOPREVIDENCIA** nas seis dimensões de gestão e o compara com as medianas observadas nas 114 organizações. A comparação linear da Figura 13 permite identificar com maior precisão a distância entre o resultado individual e a mediana geral em cada dimensão.

Figura 12 - Perfil da organização nas dimensões de Gestão de TIC em comparação com os demais



(Fonte: elaboração própria)

Figura 13 - Comparação do resultado individual e da mediana nas dimensões de Gestão de TIC

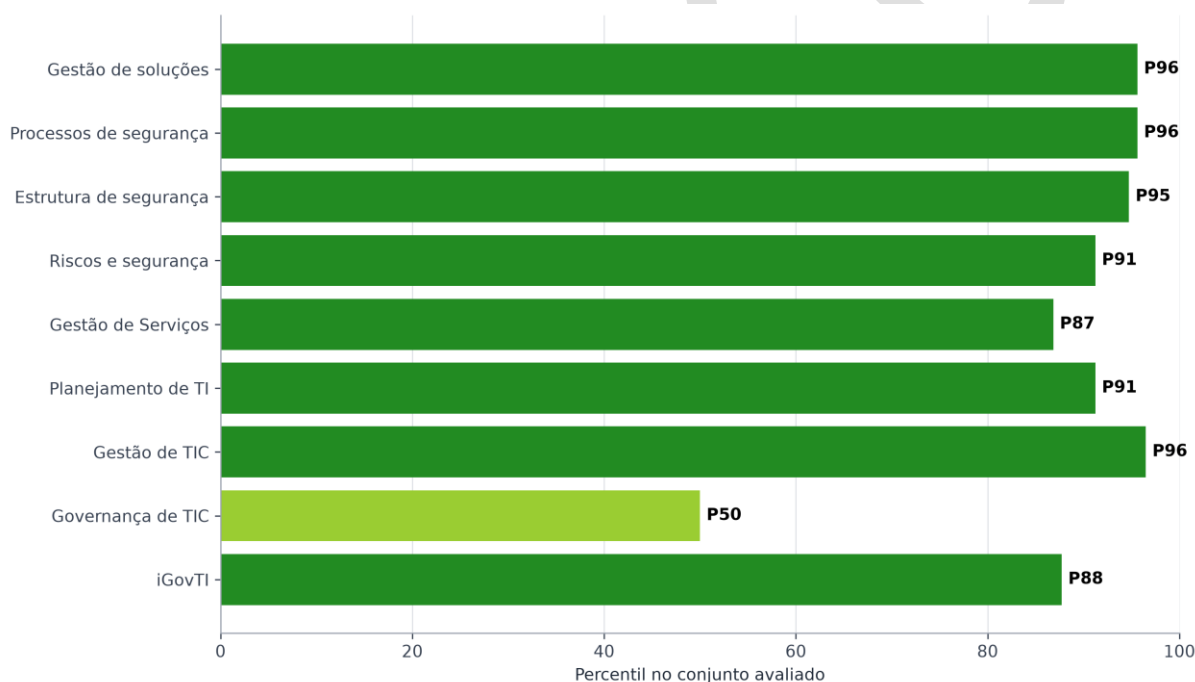


(Fonte: elaboração própria)

A Figura 14 compara a posição da organização **RIOPREVIDENCIA** com as demais organizações avaliadas em cada indicador. A letra “P” indica a posição relativa (percentil) no conjunto: **P50** representa posição próxima ao centro da distribuição; **P90** indica que a organização obteve resultado igual ou superior ao de aproximadamente 90% das organizações avaliadas; e **P20** indica que apenas cerca de 20% das organizações tiveram resultado igual ou inferior. Assim, quanto maior o valor de “P”, melhor é a posição relativa da organização naquele indicador.

Essa comparação deve ser interpretada com cautela. A posição relativa não substitui o valor do índice, o nível de maturidade nem a análise de conformidade realizada nos achados de auditoria. Ela serve apenas para indicar se o resultado da organização ficou relativamente abaixo, próximo ou acima do conjunto avaliado.

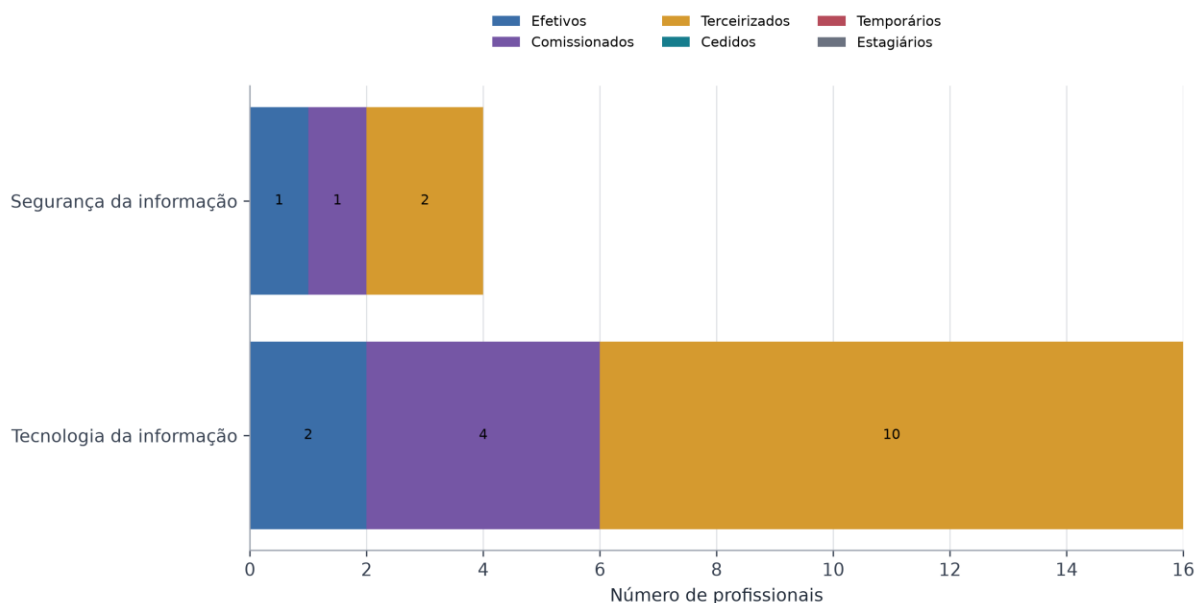
Figura 14 - Comparação da posição relativa da organização RIOPREVIDENCIA nos indicadores avaliados



(Fonte: elaboração própria)

A composição declarada da força de trabalho de TIC e de segurança da informação é apresentada na Figura 15. Os quantitativos não compõem o índice e não medem, isoladamente, suficiência de pessoal; sua avaliação depende do porte, da complexidade, da terceirização, dos serviços mantidos e dos riscos da organização.

Figura 15 - Composição declarada da força de trabalho de TIC e segurança da informação



(Fonte: elaboração própria)

2.5.1. Evolução comparável entre 2023 e 2026

A análise longitudinal foi realizada exclusivamente para organizações com correspondência institucional validada nas bases de 2023 e 2026. Para reduzir os efeitos das alterações promovidas no questionário e na estrutura de cálculo, foram utilizados, em ambos os anos, índices ajustados formados por práticas e agregados comparáveis. Esses valores têm finalidade analítica e não substituem os resultados oficiais divulgados em cada ciclo.

No caso da organização **RIOPREVIDENCIA**, o iGovTI ajustado comparável passou de 0,1873, em 2023, para 0,3590, em 2026, com variação absoluta de +0,1716.

O resultado indica avanço no conjunto harmonizado de práticas avaliadas, embora a organização tenha permanecido no nível **Iniciando** de maturidade.

Tabela 6 - Evolução dos componentes ajustados comparáveis da organização RIOPREVIDENCIA

Indicador	2023	2026	Variação absoluta
iGovTI ajustado comparável	0,1873	0,3590	+0,1716
Governança de TIC	0,0638	0,2160	+0,1522
Gestão de TIC	0,3109	0,5019	+0,1910

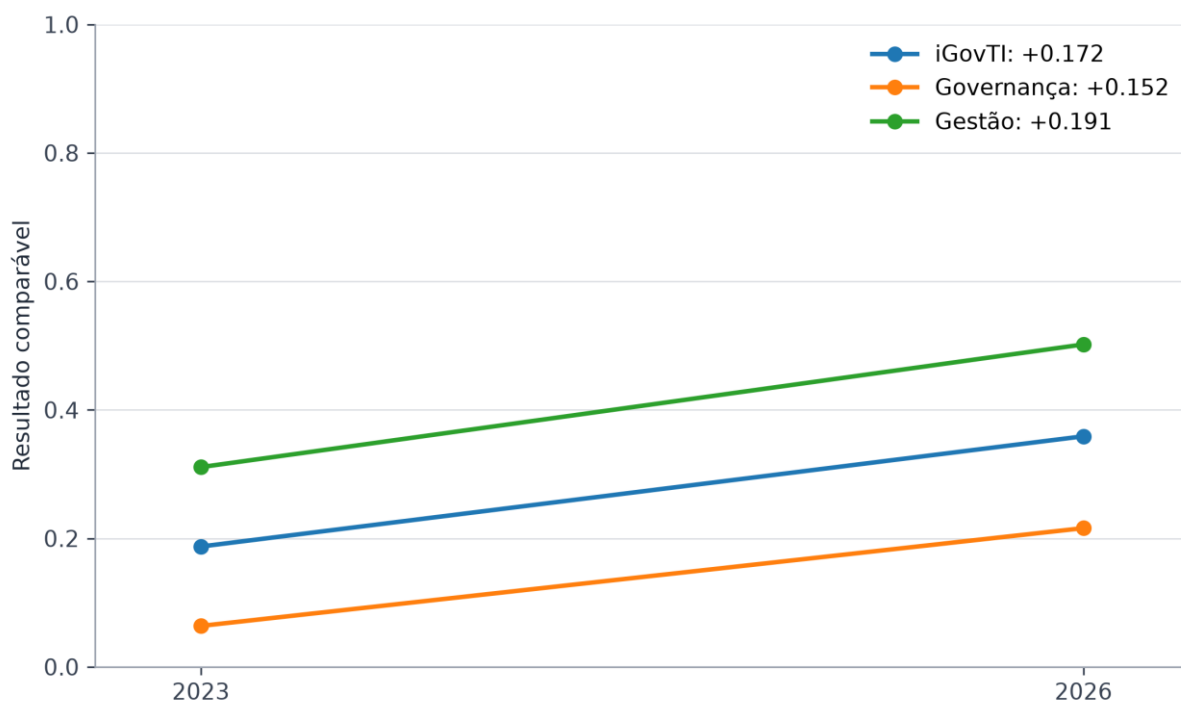
(Fonte: elaboração própria)

Os principais avanços foram observados em Processo de software (+0.8083); Gestão de projetos de TIC (+0.7875); Processos de segurança da informação (+0.4862).

As principais regressões foram observadas em Gestão de pessoas de TIC (-0.2456); Processos de contratação de TIC (-0.2403); Gestão de níveis de serviço (-0.1500).

A Figura 16 apresenta a trajetória dos três indicadores. A variação deve ser interpretada como mudança nas respostas às práticas harmonizadas, e não como comprovação isolada de melhora ou piora da efetividade da TIC. A leitura deve considerar eventuais alterações institucionais, a qualidade das informações declaradas e os achados de auditoria apresentados neste relatório.

Figura 16 - Evolução comparável da organização RIOPREVIDENCIA entre 2023 e 2026



(Fonte: elaboração própria)

A priorização de melhorias não deve buscar apenas a elevação numérica do índice. Recomenda-se concentrar esforços nas capacidades com menor resultado que, simultaneamente, estejam associadas a riscos relevantes, serviços críticos, obrigações normativas e necessidades institucionais da organização **RIOPREVIDENCIA**.

3. Resultados da Auditoria

No âmbito desta fiscalização, foram definidas questões de auditoria para orientar a avaliação da governança e da gestão de TIC. Para fins deste relatório individual preliminar, os possíveis achados decorrem da verificação das Questões 1 a 6.

Tabela 7 - Questões de auditoria com avaliação individual preliminar

Questão	Tema	Síntese do objeto avaliado
Q1	Estrutura de TIC	Existência formal, atribuições e posicionamento organizacional da área, unidade, setor ou função responsável pela TIC.
Q2	Governança e comitê de TIC	Modelo de governança e gestão de TIC, objetivos, indicadores, metas e atuação do comitê ou instância equivalente.
Q3	Planejamento de TIC	Processo de planejamento, plano de TIC vigente, aprovação, alinhamento institucional, integração orçamentária e acompanhamento.
Q4	Capacidade institucional de TIC e segurança da informação	Força de trabalho, perfis, competências, funções, vínculos e capacidade interna para sustentar a TIC e a segurança da informação.
Q5	Gestão de serviços de TIC	Catálogo de serviços, níveis mínimos de serviço, inventário de ativos, gestão de configuração e tratamento de incidentes.
Q6	Contratações de TIC	Fluxo de contratação, papéis, modelos orientativos, aprovação técnica, alinhamento ao planejamento e equipe de planejamento.

(Fonte: elaboração própria)

Não foram identificados achados individuais preliminares relacionados à Questão 1 para esta organização. Por essa razão, os achados apresentados a seguir preservam a numeração vinculada às questões de auditoria que lhes deram origem.

Os achados de auditoria decorrem da avaliação preliminar das respostas da organização **RIOPREVIDENCIA** ao questionário iGovTI 2026 e da correspondente análise de consistência documental realizada por esta Equipe de Auditoria. O trabalho consistiu no confronto sistemático entre as práticas de governança e gestão autodeclaradas pela organização e as evidências comprobatórias efetivamente encaminhadas, à luz da legislação aplicável e de padrões técnicos de referência internacional.

O presente relatório individual adota uma estrutura analítica de apresentação voltada a conferir clareza, rastreabilidade e utilidade diagnóstica às constatações. Desse modo, cada achado de auditoria está estruturado a partir dos seguintes elementos fundamentais:

- **Critérios:** as referências normativas, legais, regulamentares ou de boas práticas de gestão (como os objetivos do COBIT 2019 e normas da série ABNT NBR ISO/IEC) que estabelecem o padrão esperado de conformidade;

- **Evidências:** a relação das informações e dos documentos anexados pela organização que serviram de suporte factual para as constatações;
- **Situação Encontrada:** a descrição detalhada da realidade operacional e documental identificada no jurisdicionado, destacando-se as fragilidades e lacunas específicas em relação aos critérios adotados;
- **Conclusão da Equipe de Auditoria:** a análise técnica e o juízo profissional formulado a partir da correlação entre a situação factual e as regras de controle estabelecidas no mapa de verificação;
- **Propostas de Encaminhamento:** as recomendações preliminares propostas com o intuito de orientar a organização na correção de fragilidades e no aprimoramento de suas capacidades de governança e gestão de TIC.

Cumprе ressaltar o caráter preliminar das constatações ora apresentadas. A disponibilização deste relatório visa subsidiar a fase de comentários do gestor, permitindo à organização apresentar esclarecimentos adicionais, correções de fato ou novas informações que possam orientar a manifestação final desta Corte de Contas.

Achado 2 – Governança de TIC insuficiente para avaliar, dirigir e monitorar a tecnologia da informação.

Critérios

- COBIT 2019, EDM01.02 - Dirigir o sistema de governança: orientar estruturas, princípios, processos e práticas de governança para assegurar que a TI apoie os objetivos organizacionais;
- COBIT 2019, MEA01.04 - Avaliar o desempenho: monitorar e avaliar periodicamente o desempenho e a conformidade da TI em relação a objetivos, indicadores, metas e expectativas das partes interessadas;
- Decreto nº 12.198/2024, art. 5º - Instituição do CGD, colegiado responsável por definir diretrizes e estratégias sobre uso de recursos digitais nos órgãos e entidades da administração pública federal direta, autárquica e fundacional;
- Acórdão TCE-RJ 44.490/2024-PLEN, item II.1: necessidade de estrutura de governança de TI, especialmente Comitê de Tecnologia da Informação ou instância equivalente, com participação de áreas relevantes, responsabilidade de alinhar as ações de TI aos objetivos institucionais, priorizar investimentos e monitorar o desempenho da TI com base em indicadores e metas;
- COBIT 2019, APO01.05 - Estabelecer papéis e responsabilidades: definir, comunicar e manter papéis e responsabilidades relacionados à governança e gestão de TI.

Evidências

- **E1:** A organização declarou “Sim” no subitem c) do item 1001, mas a evidência encaminhada foi considerada insuficiente para comprovar que define os papéis e responsabilidades da área de gestão de tecnologia da informação;
 - Justificativa da avaliação: A avaliação da Equipe de Auditoria indica que não há comprovação da definição formal de papéis e responsabilidades para a área de TI. Embora o painel relacione técnicos a demandas, tal informação é meramente operacional e não equivale a um documento normativo, regimento interno ou matriz de responsabilidades que estabeleça as atribuições dos cargos. É necessária a apresentação de documento institucional que defina formalmente a estrutura de papéis e responsabilidades;
- **E2:** A organização declarou “Sim” no subitem h) do item 1001, mas a evidência encaminhada foi considerada insuficiente para comprovar que estabeleceu objetivos, indicadores e metas para a gestão de tecnologia da informação;

- Justificativa da avaliação: A avaliação da Equipe de Auditoria indica que não foram apresentados objetivos, indicadores ou metas formalmente estabelecidos para a gestão de TI. A evidência consiste apenas em um painel de monitoramento operacional, sem registro documental que formalize metas quantitativas, indicadores estratégicos ou objetivos de gestão aprovados pela organização. É necessária a apresentação de instrumento formal contendo o planejamento e a aprovação desses elementos;
- **E3:** A organização declarou “Sim” no subitem a) do item 1002, mas a evidência encaminhada foi considerada insuficiente para comprovar que rotinas de monitoramento do desempenho da gestão de tecnologia da informação estão definidas;
 - Justificativa da avaliação: A avaliação realizada indica que o item não foi atendido. Embora existam sistemas de coleta de dados em operação, não foram apresentados documentos normativos, manuais ou atos administrativos que definam formalmente as rotinas de monitoramento. A análise crítica aponta que capturas de tela isoladas são insuficientes para comprovar a existência de processos de trabalho estabelecidos. A lacuna reside na ausência de normatização formal dos procedimentos de acompanhamento;
- **E4:** Resposta negativa ao detalhamento e) do item 1001 do Questionário, para verificar se a organização dispõe de comitê de tecnologia da informação composto por representantes de áreas relevantes da organização.

Situação encontrada

A governança de TIC compreende o conjunto de estruturas, papéis, responsabilidades, diretrizes e mecanismos de acompanhamento por meio dos quais a alta administração avalia, dirige e monitora o uso da tecnologia da informação. Sua finalidade é assegurar que os recursos de TIC apoiem os objetivos institucionais, sejam priorizados de forma transparente e tenham desempenho acompanhado com base em critérios objetivos.

Para que a governança de TIC esteja estruturada, a alta administração deve estabelecer modelo básico de governança e gestão de TIC, com papéis, responsabilidades, objetivos, indicadores e metas claras, além de assegurar a existência e o funcionamento regular de um Comitê de TIC ou instância colegiada equivalente.

Os critérios de boas práticas orientam que a organização deve dirigir o sistema de governança, monitorar o desempenho e a conformidade da TIC, definir papéis e responsabilidades e instituir instância colegiada capaz de alinhar ações de TIC aos objetivos institucionais, priorizar investimentos e acompanhar o desempenho com base em

indicadores e metas¹. Esses requisitos convergem com a necessidade de instância colegiada de governança digital, conforme diretriz do Decreto nº 12.198/2024², e com as deliberações do Acórdão TCE-RJ 44.490/2024-PLEN³.

Com base na análise das respostas aos itens 1001 e 1002 do questionário aplicado e da avaliação das evidências documentais anexadas, não foi demonstrado atendimento integral a esses requisitos de governança. A Equipe de Auditoria identificou fragilidades nos seguintes aspectos:

- **Modelo básico de governança e gestão de TIC:** a ausência ou insuficiência de modelo formalizado não demonstra aderência aos critérios de direção do sistema de governança e avaliação de desempenho (COBIT 2019, EDM01.02/MEA01.04) e ao Acórdão TCE-RJ 44.490/2024-PLEN (item II.1), gerando baixa clareza sobre papéis, responsabilidades, objetivos, indicadores e metas da TIC.
- **Instituição do Comitê de TIC:** a não instituição formal não se alinha ao Acórdão TCE-RJ 44.490/2024-PLEN (item II.1), ao COBIT 2019 (APO01.05) e à diretriz de referência do Decreto nº 12.198/2024 (art. 5º), dificultando a existência de instância colegiada para deliberação sobre prioridades, projetos, riscos, serviços, orçamento e contratações de TIC.

Essas situações ensejaram o presente achado e serão detalhadas nas subseções seguintes.

Modelo básico de governança e gestão de TIC

O modelo básico de governança e gestão de TIC deve explicitar como a alta administração orienta, acompanha e responsabiliza a atuação da tecnologia da informação. Esse modelo deve conter, ao menos, diretrizes, papéis, responsabilidades, objetivos, indicadores, metas e forma de acompanhamento periódico.

O COBIT 2019, no objetivo EDM01.02, orienta a direção do sistema de governança por meio de estruturas, princípios, processos e práticas que assegurem que a TI apoie os objetivos organizacionais. Em complemento, o objetivo MEA01.04 trata do monitoramento e da avaliação periódica do desempenho e da conformidade da TI em relação a objetivos, indicadores, metas e expectativas das partes interessadas.

¹ No COBIT 2019, o sistema de governança deve ser dirigido por estruturas, princípios, processos e práticas que assegurem que a TI apoie os objetivos organizacionais, com papéis e responsabilidades definidos e desempenho periodicamente monitorado.

² O Decreto nº 12.198/2024 disciplina, no âmbito federal, o Comitê de Governança Digital como colegiado responsável por diretrizes e estratégias sobre o uso de recursos digitais, servindo como referência normativa para a estruturação de instâncias colegiadas de governança digital.

³ O Acórdão TCE-RJ 44.490/2024-PLEN, item II.1, registra a necessidade de estrutura de governança de TI, especialmente Comitê de Tecnologia da Informação ou instância equivalente, com participação de áreas relevantes e atribuições de alinhamento, priorização e monitoramento.

A existência e a suficiência desse modelo devem ser demonstradas por políticas, diretrizes, definição de papéis e responsabilidades, objetivos, indicadores, metas, relatórios de acompanhamento, medições de desempenho ou instrumentos equivalentes.

Da análise das respostas aos itens 1001 e 1002 e da documentação apresentada, verificou-se que o modelo básico de governança e gestão de TIC não se mostrou suficientemente estruturado quanto a papéis, responsabilidades, objetivos, indicadores, metas ou forma de acompanhamento periódico, em razão dos seguintes elementos identificados pela Equipe de Auditoria:

- No subitem c) do item 1001, a organização declarou a prática avaliada, mas a evidência foi insuficiente para comprovar que define os papéis e responsabilidades da área de gestão de tecnologia da informação (E1);
- No subitem h) do item 1001, a organização declarou a prática avaliada, mas a evidência foi insuficiente para comprovar que estabeleceu objetivos, indicadores e metas para a gestão de tecnologia da informação (E2);
- No subitem a) do item 1002, a organização declarou a prática avaliada, mas a evidência foi insuficiente para comprovar que rotinas de monitoramento do desempenho da gestão de tecnologia da informação estão definidas (E3).

A ausência ou a insuficiência de um modelo básico de governança e gestão de TIC acarreta o risco de indefinição sobre a direção estratégica da tecnologia da informação e sobre os resultados esperados da função de TIC.

Instituição formal do Comitê de TIC ou instância equivalente

O Comitê de TIC ou instância equivalente é mecanismo relevante para estruturar a participação da alta administração e das áreas interessadas nas decisões de tecnologia da informação. Sua formalização permite definir composição, competências, periodicidade mínima, forma de deliberação e responsabilidades pelo acompanhamento das decisões.

O Decreto nº 12.198/2024, art. 5º, adotado como critério de referência, prevê colegiado responsável por definir diretrizes e estratégias sobre uso de recursos digitais no âmbito federal. O Acórdão TCE-RJ 44.490/2024-PLEN, item II.1, reforça a necessidade de estrutura de governança de TI, especialmente Comitê de Tecnologia da Informação ou instância equivalente, com participação de áreas relevantes.

Em alinhamento, o COBIT 2019, no objetivo APO01.05, orienta a definição, comunicação e manutenção de papéis e responsabilidades relacionados à governança e gestão de TI.

A instituição formal do Comitê deve ser demonstrada por ato, norma, regimento, portaria ou documento equivalente que estabeleça a instância, sua composição, competências, periodicidade ou forma de deliberação.

Da análise das respostas ao item 1001 e da documentação apresentada, verificou-se que a instituição formal de Comitê de TIC ou instância equivalente não se mostrou suficientemente demonstrada, em razão dos seguintes elementos identificados pela Equipe de Auditoria:

- No subitem e) do item 1001, não houve declaração afirmativa quanto à prática avaliada: dispõe de comitê de tecnologia da informação composto por representantes de áreas relevantes da organização (E4).

A ausência de instituição formal do Comitê de TIC ou instância equivalente fragiliza a governança, uma vez que a organização deixa de contar com foro institucional normatizado para deliberação sobre prioridades, projetos, riscos, serviços, orçamento e contratações de TIC.

Conclusão

As fragilidades identificadas na governança de TIC reduzem a segurança de que a organização disponha de mecanismos suficientes para avaliar, dirigir e monitorar a tecnologia da informação de forma alinhada aos objetivos institucionais.

Em razão das lacunas descritas, são propostas recomendações preliminares voltadas à estruturação e à adequação dos mecanismos de governança de TIC efetivamente apontados neste achado, observados os critérios aplicáveis indicados nas seções anteriores.

Propostas de Encaminhamento

- **Comunicação com Recomendação** para que estabeleça modelo básico de governança e gestão de TIC, atentando-se, minimamente, em definir papéis e responsabilidades, objetivos, indicadores, metas e forma de acompanhamento periódico do desempenho da TIC pela alta administração;
- **Comunicação com Recomendação** para que institua formalmente Comitê de TIC ou instância equivalente, compatível com o porte e a estrutura decisória da organização, atentando-se, minimamente, em definir sua composição, competências, periodicidade de reuniões, forma de registro das deliberações e acompanhamento dos encaminhamentos.

Achado 3 – Planejamento de TIC insuficiente para orientar a gestão, o orçamento e as contratações de TIC

Critérios

- COBIT 2019, APO02.05 - Definir o plano e o roteiro estratégico: estabelecer plano e roteiro de TIC que traduzam a estratégia em iniciativas, prioridades, recursos, dependências, prazos e benefícios esperados;
- COBIT 2019, APO06.03 - Criar e manter orçamentos: elaborar e manter orçamento de TIC alinhado ao portfólio, ao planejamento e às prioridades aprovadas;
- Acórdão 1.411/2014-TCU-Plenário, item 9.1.6 e subitens 9.1.6.1 a 9.1.6.4: necessidade de instituir formalmente plano diretor de TI, contemplando desdobramento de diretrizes estratégicas, vinculação das ações de TI a indicadores e metas de negócio, vinculação das ações de TI a indicadores e metas de serviços ao cidadão e vinculação das ações priorizadas ao orçamento de TI;
- Acórdão TCE-RJ 44.490/2024-PLEN, item II.3 e subitens II.3.1 a II.3.5: necessidade de estabelecer processo estruturado, com participação de representantes das principais secretarias, para elaborar, manter e revisar periodicamente o PDTI, contemplando objetivos, indicadores e metas de TI alinhados aos objetivos de negócio, riscos que possam impactar objetivos e metas, projetos, aquisições e ações necessárias, alocação de recursos e ações de divulgação e monitoramento do PDTI após aprovação pela autoridade máxima.

Evidências

- **E1:** A organização declarou “Sim” no subitem a) do item 2102, mas a evidência encaminhada foi considerada insuficiente para comprovar que o plano de tecnologia da informação (plano de TI) é aprovado pelo dirigente máximo da organização ou por dirigente ou colegiado que integra a alta administração;
 - Justificativa da avaliação: A evidência apresentada é insuficiente para demonstrar o atendimento ao critério. Embora o plano cite a criação do Comitê PEDTIC por meio da Portaria nº 505/2023, não foi apresentado ato formal, despacho ou documento assinado que comprove a aprovação final do plano pelo dirigente máximo ou por colegiado da alta administração. Ausência de evidência documental da aprovação oficial do PEDTIC 2024;
- **E2:** A organização declarou “Sim” no subitem c) do item 2802, mas a evidência encaminhada foi considerada insuficiente para comprovar que na elaboração do PCA são considerados os demais instrumentos de planejamento da organização;

- Justificativa da avaliação: A Equipe de Auditoria não identificou elementos que conectem o PCA aos demais instrumentos de planejamento institucional, tais como PPA, LDO ou plano estratégico. A evidência restringe-se aos dados disponibilizados no portal nacional, sem demonstrar o alinhamento ou integração com outros instrumentos. Ausência de comprovação documental da integração do PCA com o planejamento institucional;
- **E3:** A organização declarou “Sim” no subitem d) do item 2802, mas a evidência encaminhada foi considerada insuficiente para comprovar que o PCA fundamenta a proposta orçamentária da organização;
 - Justificativa da avaliação: A Equipe de Auditoria não encontrou evidências que demonstrem a correlação entre o PCA e a proposta orçamentária. Embora o portal exiba o valor total estimado, não há registro da fundamentação orçamentária decorrente deste plano. Ausência de documento, nota técnica ou memória de cálculo que vincule o PCA à proposta orçamentária.

Situação encontrada

O planejamento de TIC é instrumento fundamental para traduzir diretrizes institucionais em iniciativas, prioridades, recursos, prazos, responsáveis e resultados esperados. Sob a perspectiva de governança pública, a administração deve executar processo formal de planejamento, contar com plano de TIC formalmente aprovado, assegurar participação das áreas finalísticas, alinhar o plano ao planejamento institucional, integrá-lo ao orçamento e às contratações e acompanhá-lo periodicamente.

Os critérios de boas práticas indicam que o planejamento de TIC deve estabelecer plano e roteiro estratégico, manter orçamento alinhado ao portfólio e às prioridades aprovadas, vincular ações de TIC a indicadores, metas e orçamento de TI, e contemplar processo estruturado de elaboração, manutenção e revisão periódica do PDTI⁴.

Com base na análise das respostas aos itens 2101, 2102, 2802 e 2804 do questionário aplicado e da avaliação das evidências documentais anexadas, não foi demonstrado atendimento integral a esses requisitos de planejamento. A Equipe de Auditoria identificou fragilidades nos seguintes aspectos:

- **Aprovação formal do plano:** a ausência de aprovação formal não demonstra aderência aos critérios de formalização do planejamento de TIC, reduzindo sua legitimidade institucional para orientar a gestão, os projetos, o orçamento e as contratações da organização.

⁴ Os critérios de planejamento de TIC convergem para a necessidade de plano formal, aprovado, vigente, alinhado à estratégia institucional, integrado ao orçamento e às contratações e acompanhado periodicamente.

- **Integração orçamentária e operacional:** a ausência de vínculo demonstrado com orçamento e contratações de TIC não demonstra aderência ao COBIT 2019 (APO06.03), ao Acórdão 1.411/2014-TCU-Plenário e ao Acórdão TCE-RJ 44.490/2024-PLEN, favorecendo aquisições reativas, não priorizadas e desalinhadas das metas de TIC.

Essas situações ensejaram o presente achado e serão detalhadas nas subseções seguintes.

Aprovação formal do plano de TIC

O plano de TIC deve ser formalmente aprovado pelo dirigente máximo da organização ou por dirigente ou colegiado integrante da alta administração, de modo a conferir legitimidade institucional ao instrumento.

O Acórdão 1.411/2014-TCU-Plenário e o Acórdão TCE-RJ 44.490/2024-PLEN reforçam a necessidade de plano diretor ou instrumento equivalente formalmente instituído e aprovado, capaz de orientar as ações de TIC.

A aprovação deve ser demonstrada por ato formal da instância competente ou por registro equivalente que identifique o plano aprovado, a autoridade responsável e a data da deliberação.

Da análise das respostas ao item 2102 e da documentação apresentada, verificou-se que a aprovação formal do plano de TIC por autoridade ou instância competente não se mostrou suficientemente demonstrada, em razão dos seguintes elementos identificados pela Equipe de Auditoria:

- No subitem a) do item 2102, a organização declarou a prática avaliada, mas a evidência foi insuficiente para comprovar que o plano de tecnologia da informação (plano de TI) é aprovado pelo dirigente máximo da organização ou por dirigente ou colegiado que integra a alta administração (E1).

A ausência de comprovação da aprovação formal do plano de TIC reduz a segurança quanto à legitimidade institucional do instrumento para orientar a gestão, os projetos, o orçamento e as contratações de tecnologia da informação.

Vínculo com orçamento e contratações de TIC

O planejamento de TIC deve ser vinculado com a proposta orçamentária, o plano de contratações e as contratações executadas. Essa integração é necessária para que as iniciativas priorizadas tenham suporte financeiro, sejam convertidas em contratações coerentes e possam ser acompanhadas ao longo da execução.

O COBIT 2019, APO06.03, orienta a criação e manutenção de orçamento de TIC alinhado ao portfólio, ao planejamento e às prioridades aprovadas. O Acórdão 1.411/2014-TCU-Plenário também exige vinculação das ações priorizadas ao orçamento de TI, e o

Acórdão TCE-RJ 44.490/2024-PLEN prevê projetos, aquisições, ações necessárias e alocação de recursos no PDTI.

Da análise das respostas aos itens 2102, 2802 e 2804 e da documentação apresentada, verificou-se que o vínculo entre o plano de TIC, a proposta orçamentária, o plano de contratações ou as contratações de TIC executadas não se mostrou suficientemente demonstrado, em razão dos seguintes elementos identificados pela Equipe de Auditoria:

- No subitem c) do item 2802, a organização declarou a prática avaliada, mas a evidência foi insuficiente para comprovar que na elaboração do PCA são considerados os demais instrumentos de planejamento da organização (E2);
- No subitem d) do item 2802, a organização declarou a prática avaliada, mas a evidência foi insuficiente para comprovar que o PCA fundamenta a proposta orçamentária da organização (E3).

A falta de integração demonstrada entre o planejamento de tecnologia, as previsões orçamentárias, o plano de contratações e as contratações executadas eleva o risco de aquisições isoladas, reativas ou insuficientemente priorizadas sob a perspectiva técnica.

Conclusão

As fragilidades identificadas no planejamento de TIC reduzem a segurança de que a organização disponha, conforme aplicável ao caso concreto, de processo e instrumento suficientes para direcionar iniciativas, priorizar recursos, alinhar projetos às necessidades institucionais e integrar orçamento e contratações à estratégia de tecnologia.

Em razão das lacunas descritas, são propostas recomendações preliminares voltadas à adequação dos aspectos de planejamento de TIC efetivamente apontados neste achado, observados os critérios aplicáveis indicados nas seções anteriores.

Propostas de Encaminhamento

- **Comunicação com Recomendação** para que submeta o plano de TIC à aprovação formal do dirigente máximo ou de dirigente ou colegiado integrante da alta administração, mantendo registro do respectivo ato de aprovação;
- **Comunicação com Recomendação** para que integre o plano de TIC à proposta orçamentária, ao plano de contratações e às contratações de TIC, atentando-se, minimamente, em priorizar as demandas conforme sua relevância, seus riscos e a capacidade de execução da organização.

Achado 4 – Capacidade institucional insuficiente para sustentar a gestão de TIC e segurança da informação

Critérios

- COBIT 2019, APO01.05 - Estabelecer papéis e responsabilidades: definir, comunicar e manter papéis e responsabilidades relacionados à governança e gestão de TIC;
- COBIT 2019, APO07.01 - Adquirir e manter pessoal adequado e apropriado: assegurar quantidade e perfil de profissionais compatíveis com as necessidades de TIC;
- COBIT 2019, APO07.02 - Identificar pessoal-chave de TI: identificar funções e pessoas críticas para reduzir dependência individual, perda de conhecimento e descontinuidade;
- COBIT 2019, APO07.03 - Manter habilidades e competências do pessoal: identificar, desenvolver e manter competências necessárias à execução das responsabilidades de TIC;
- COBIT 2019, APO07.05 - Planejar e monitorar o uso de recursos humanos de TI e de negócio: planejar, alocar e acompanhar capacidade de pessoal para iniciativas, operações e serviços de TIC;
- COBIT 2019, APO07.06 - Gerenciar pessoal contratado: controlar o uso de pessoal terceirizado ou externo, preservando responsabilização, supervisão e retenção de conhecimento;
- COBIT 2019, APO10.04 - Gerenciar risco de fornecedores: identificar e tratar riscos decorrentes de fornecedores, contratos e dependências externas relevantes para TIC;
- COBIT 2019, DSS01.02 - Gerenciar serviços de TI terceirizados: assegurar que serviços terceirizados sejam supervisionados, medidos e integrados aos controles da organização;
- ABNT NBR ISO/IEC 27001:2022, cláusulas 5.3 e 7.2: definir responsabilidades e autoridades para segurança da informação e assegurar competências necessárias às funções atribuídas;
- ABNT NBR ISO/IEC 27002:2022, controles 5.2 e 6.3: definir papéis e responsabilidades de segurança da informação e promover conscientização, educação e treinamento em segurança.

Evidências

- **E1:** Resposta negativa ao detalhamento c) do item 2703 do Questionário, para verificar se definiu-se, de maneira documentada, um quantitativo necessário de pessoal da área de tecnologia da informação e segurança da informação;
- **E2:** A organização declarou “Sim” no subitem d) do item 2708, mas a evidência encaminhada foi considerada insuficiente para comprovar que possui em sua estrutura cargos ou funções formalmente atribuídas à área de segurança da informação;
 - Justificativa da avaliação: A evidência não demonstra a existência de funções específicas em segurança da informação na estrutura organizacional. A ‘Coordenadoria DPO’ presente no organograma está associada à conformidade e proteção de dados pessoais, não constituindo função atribuída à segurança da informação em sentido técnico ou operacional. Não há unidade ou função que remeta explicitamente à segurança da informação ou segurança cibernética. Falta a indicação de unidade ou função formalmente designada para tal finalidade;
- **E3:** A organização declarou “Sim” no subitem a) do item 2702, mas a evidência encaminhada foi considerada insuficiente para comprovar que as responsabilidades e atribuições das ocupações ou grupo de ocupações da área de tecnologia da informação estão definidas, documentadas e publicadas;
 - Justificativa da avaliação: A documentação fornecida restringe-se a uma matriz de habilidades técnicas de indivíduos, não contendo a definição das responsabilidades e atribuições inerentes às ocupações ou grupos de ocupações. Não foram apresentados normativos, descrições de cargos ou documentos institucionais que estabeleçam o escopo de atuação. Adicionalmente, inexistência de evidência que comprove a publicação formal dessas responsabilidades;
- **E4:** A organização declarou “Sim” no subitem b) do item 2704, mas a evidência encaminhada foi considerada insuficiente para comprovar que os gestores são selecionados com base em perfil profissional previamente definido e documentado, e compatível com o cargo ou função para o qual tenha sido indicado;
 - Justificativa da avaliação: A avaliação da Equipe de Auditoria indica a não conformidade, visto que a documentação apresentada não comprova a seleção de gestores com base em perfil profissional previamente definido e compatível com a função. O Regimento Interno limita-se a descrever a

estrutura e competências das unidades, sem estabelecer ou referenciar requisitos profissionais específicos ou processos de seleção para os cargos de gestão de TI e segurança da informação. A evidência carece de documentos que comprovem a existência de perfis profissionais, critérios de compatibilidade e o registro do procedimento de escolha fundamentado em critérios objetivos;

- **E5:** Resposta negativa ao detalhamento b) do item 2705 do Questionário, para verificar se as lacunas de competências de liderança e gestão necessárias para a atuação dos gestores da organização são identificadas e documentadas;
- **E6:** Resposta negativa ao detalhamento c) do item 2705 do Questionário, para verificar se as lacunas de competências técnicas da área de tecnologia da informação necessárias para a atuação dos colaboradores da organização são identificadas e documentadas;
- **E7:** Resposta negativa ao detalhamento d) do item 2705 do Questionário, para verificar se as lacunas de competências técnicas da área de segurança da informação necessárias para a atuação dos colaboradores da organização são identificadas e documentadas;
- **E8:** Resposta negativa ao detalhamento a) do item 2706 do Questionário, para verificar se a organização elabora plano de capacitação (plano de treinamento) visando o tratamento das lacunas de competência identificadas;
- **E9:** Predomínio de profissionais terceirizados de TI em relação ao quantitativo de profissionais internos, conforme informado em resposta ao item 0105.

Situação encontrada

A capacidade institucional de TIC e segurança da informação pressupõe dispor de recursos humanos, competências, perfis profissionais, funções e vínculos contratuais adequados para planejar, coordenar, gerir, proteger, contratar, fiscalizar e sustentar o ambiente tecnológico. Sob a perspectiva de controle e governança, a estruturação formal de uma unidade de tecnologia deve ser acompanhada de capacidade técnica compatível para exercer a supervisão de suas atribuições estratégicas.

Os critérios de boas práticas indicam que a organização deve formalizar a designação de papéis e responsabilidades, assegurar o dimensionamento apropriado do quadro de pessoal, mapear funções críticas, capacitar periodicamente a equipe e supervisionar de forma estrita a atuação de prestadores de serviços externos⁵.

⁵ Os critérios de capacidade institucional de TIC e segurança da informação concentram-se em pessoal adequado, competências, papéis, responsabilidades, retenção de conhecimento e supervisão de terceiros.

Com base na análise das respostas aos itens 0101, 0105, 2701, 2702, 2703, 2704, 2705, 2706, 2708, 2801 e 2804 do questionário aplicado e da avaliação das evidências documentais anexadas, não foi demonstrada capacidade institucional suficiente para sustentar a gestão de TIC e segurança da informação. A Equipe de Auditoria identificou fragilidades nos seguintes aspectos:

- **Dimensionamento de pessoal:** a ausência de definição de parâmetros de pessoal não demonstra aderência aos critérios de planejamento de recursos humanos (COBIT 2019, APO07.01), elevando o risco de subdimensionamento ou má alocação da equipe técnica.
- **Cargos e carreiras específicas:** a ausência de cargos, funções ou perfis técnicos estruturados não demonstra aderência às boas práticas de atração e retenção de pessoal (COBIT 2019, APO07.01), podendo reduzir a responsabilização e a continuidade da gestão tecnológica.
- **Perfis profissionais:** a ausência ou inobservância de perfis profissionais mínimos para a escolha de gestores e técnicos não demonstra aderência às diretrizes de manutenção de competências (COBIT 2019, APO07.01/APO07.03 e ISO/IEC 27002:2022, 5.2/6.3), reduzindo a segurança de que os responsáveis possuam qualificação compatível com as funções exercidas.
- **Lacunas de competência:** a ausência de identificação ou tratamento de lacunas de treinamento não demonstra aderência às recomendações de capacitação técnica (COBIT 2019, APO07.03 e ISO/IEC 27002:2022, 6.3), podendo fragilizar a operação de segurança e o gerenciamento de ativos de TIC.
- **Dependência externa:** a dependência externa relevante sem capacidade interna suficiente para coordenar e fiscalizar a TIC não demonstra aderência às boas práticas de gestão de pessoal contratado e terceirizações (COBIT 2019, APO07.06, APO10.04 e DSS01.02), elevando riscos à governabilidade técnica e à continuidade das atividades do órgão.

Essas situações ensejaram o presente achado e serão detalhadas nas subseções seguintes.

Quantitativo necessário de pessoal de TIC e segurança da informação

A definição do quantitativo necessário de pessoal permite avaliar se a força de trabalho disponível é compatível com as demandas, riscos e responsabilidades da organização.

O COBIT 2019, APO07.01 e APO07.05, exige que a organização assegure quantidade e perfil de profissionais compatíveis com as necessidades de TIC e planeje a alocação de recursos humanos para iniciativas, operações e serviços.

Da análise das respostas ao item 2703 e da documentação apresentada, verificou-se que a definição do quantitativo necessário de pessoal de TIC e segurança da informação com base em critério ou procedimento técnico não se mostrou suficientemente demonstrada, em razão dos seguintes elementos identificados pela Equipe de Auditoria:

- No subitem c) do item 2703, não houve declaração afirmativa quanto à prática avaliada: definiu-se, de maneira documentada, um quantitativo necessário de pessoal da área de tecnologia da informação e segurança da informação (E1).

A ausência de dimensionamento técnico do quadro de pessoal reduz a disponibilidade de bases objetivas para subsidiar decisões sobre contratações, provimentos, planos de capacitação ou eventual compartilhamento de estruturas com outras organizações.

Cargos, funções, perfis ou ocupações específicas de TIC e segurança da informação

Cargos, funções, gratificações, perfis ou ocupações específicas de TIC e segurança da informação ajudam a estruturar responsabilidades, atrair profissionais, definir requisitos mínimos e reduzir improvisação na alocação de pessoas.

O COBIT 2019, APO01.05, APO07.01 e APO07.02, orienta a definição de papéis e responsabilidades, a manutenção de pessoal adequado e a identificação de funções críticas de TI.

Da análise das respostas ao item 2708 e da documentação apresentada, verificou-se que a existência de cargos, funções, gratificações, perfis ou ocupações específicas de TIC e segurança da informação não se mostrou suficientemente demonstrada, em razão dos seguintes elementos identificados pela Equipe de Auditoria:

- No subitem d) do item 2708, a organização declarou a prática avaliada, mas a evidência foi insuficiente para comprovar que possui em sua estrutura cargos ou funções formalmente atribuídas à área de segurança da informação (E2).

A ausência de cargos, funções, gratificações, perfis ou ocupações específicas de TIC e segurança da informação pode reduzir a capacidade de atração, responsabilização e retenção de profissionais com perfil compatível com as necessidades da área.

Perfis profissionais de TIC e segurança da informação

A definição de perfis profissionais mínimos para gestores e colaboradores de TIC e segurança da informação é necessária para que as pessoas designadas possuam competências compatíveis com suas responsabilidades.

O COBIT 2019, APO01.05 e APO07.03, orienta a definição de papéis, responsabilidades e competências necessárias. A ABNT NBR ISO/IEC 27001:2022 também exige competências adequadas às funções atribuídas em segurança da informação.

Da análise das respostas aos itens 2701, 2702 e 2704 e da documentação apresentada, verificou-se que a definição ou utilização de perfis profissionais mínimos para gestores e colaboradores de TIC e segurança da informação não se mostrou suficientemente demonstrada, em razão dos seguintes elementos identificados pela Equipe de Auditoria:

- No subitem a) do item 2702, a organização declarou a prática avaliada, mas a evidência foi insuficiente para comprovar que as responsabilidades e atribuições das ocupações ou grupo de ocupações da área de tecnologia da informação estão definidas, documentadas e publicadas (E3);
- No subitem b) do item 2704, a organização declarou a prática avaliada, mas a evidência foi insuficiente para comprovar que os gestores são selecionados com base em perfil profissional previamente definido e documentado, e compatível com o cargo ou função para o qual tenha sido indicado (E4).

A ausência de perfis profissionais mínimos ou de sua utilização como referência para designação de gestores e técnicos eleva o risco de alocação de colaboradores sem qualificação compatível com atividades críticas de tecnologia da informação e segurança da informação.

Identificação e tratamento de lacunas de competências

A organização deve identificar periodicamente lacunas de competências dos gestores e colaboradores de TIC e segurança da informação e definir medidas de tratamento, como capacitação, realocação, provimento, apoio especializado, compartilhamento de estrutura ou contratação com transferência de conhecimento.

O COBIT 2019, APO07.03, orienta a manutenção de habilidades e competências necessárias à execução das responsabilidades de TIC. A ABNT NBR ISO/IEC 27002:2022, controles 5.2 e 6.3, reforça a definição de responsabilidades e a promoção de conscientização, educação e treinamento em segurança.

Da análise das respostas aos itens 2705 e 2706 e da documentação apresentada, verificou-se que a identificação ou o tratamento de lacunas de competências dos gestores e colaboradores de TIC e segurança da informação não se mostrou suficientemente demonstrado, em razão dos seguintes elementos identificados pela Equipe de Auditoria:

- No subitem b) do item 2705, não houve declaração afirmativa quanto à prática avaliada: as lacunas de competências de liderança e gestão necessárias para a atuação dos gestores da organização são identificadas e documentadas (E5);
- No subitem c) do item 2705, não houve declaração afirmativa quanto à prática avaliada: as lacunas de competências técnicas da área de tecnologia da informação

necessárias para a atuação dos colaboradores da organização são identificadas e documentadas (E6);

- No subitem d) do item 2705, não houve declaração afirmativa quanto à prática avaliada: as lacunas de competências técnicas da área de segurança da informação necessárias para a atuação dos colaboradores da organização são identificadas e documentadas (E7);
- No subitem a) do item 2706, não houve declaração afirmativa quanto à prática avaliada: elabora plano de capacitação (plano de treinamento) visando o tratamento das lacunas de competência identificadas (E8).

A ausência de diagnóstico regular sobre competências internas e de medidas para tratamento de lacunas dificulta o acompanhamento da evolução tecnológica e pode reduzir a capacidade da equipe técnica de administrar sistemas, infraestrutura e controles de segurança da informação de forma compatível com os riscos existentes.

Dependência externa e capacidade interna de coordenação e fiscalização

A utilização de terceiros ou de estrutura externa para execução de atividades de TIC não elimina a responsabilidade da organização pela coordenação, planejamento, aprovação técnica, fiscalização contratual e retenção de conhecimento.

O COBIT 2019, APO07.06, APO10.04 e DSS01.02, orienta o controle de pessoal contratado, a gestão de riscos de fornecedores e a supervisão de serviços terceirizados de TI, preservando responsabilização, medição, integração aos controles e retenção de conhecimento.

Da análise das respostas aos itens 0101 e 0105 e da documentação apresentada, verificou-se que a existência de capacidade interna para coordenar, planejar, fiscalizar e reter conhecimento quando a operação de TIC depende de terceiros ou de estrutura externa não se mostrou suficientemente demonstrada, em razão dos seguintes elementos identificados pela Equipe de Auditoria:

- O quantitativo informado indicou predominância de profissionais terceirizados em relação aos profissionais internos de TIC (E9).

O estabelecimento de modelo operacional baseado predominantemente em recursos externos, sem capacidade interna suficiente de coordenação e supervisão, pode reduzir a governabilidade técnica, a retenção de conhecimento e a continuidade das operações de TIC.

Conclusão

As fragilidades identificadas na capacidade institucional de TIC e segurança da informação reduzem a segurança de que a organização disponha, conforme aplicável ao

caso concreto, de pessoal, competências, papéis, perfis profissionais e mecanismos de supervisão suficientes para sustentar a gestão, a proteção, as contratações, a fiscalização e a continuidade dos serviços tecnológicos.

Em razão das lacunas descritas, são propostas recomendações preliminares voltadas à adequação dos aspectos de capacidade institucional de TIC e segurança da informação efetivamente apontados neste achado, observados os critérios aplicáveis indicados nas seções anteriores.

Propostas de Encaminhamento

- **Comunicação com Recomendação** para que estime e mantenha atualizado o quantitativo necessário de pessoal de TIC e segurança da informação, considerando o porte e a complexidade da organização, os serviços críticos, os sistemas mantidos, as contratações vigentes e os riscos relevantes;
- **Comunicação com Recomendação** para que avalie a necessidade de instituir cargos, funções, gratificações, perfis ou ocupações específicas de TIC e segurança da informação e adote a solução compatível com as necessidades institucionais e a capacidade administrativa da organização;
- **Comunicação com Recomendação** para que defina perfis profissionais mínimos para gestores e colaboradores de TIC e segurança da informação, atentando-se, minimamente, em estabelecer conhecimentos, habilidades, experiência e responsabilidades requeridos e utilizar esses perfis na seleção e designação dos responsáveis;
- **Comunicação com Recomendação** para que realize diagnóstico periódico das lacunas de competências dos gestores e colaboradores de TIC e segurança da informação e estabeleça plano de tratamento, contemplando, conforme a necessidade, capacitação, realocação, provimento, apoio especializado, compartilhamento de estrutura ou contratação com transferência de conhecimento;
- **Comunicação com Recomendação** para que avalie o modelo de operação de TIC e adote medidas proporcionais para assegurar capacidade interna suficiente de coordenação, planejamento, aprovação técnica, fiscalização contratual e retenção de conhecimento, especialmente quando a execução das atividades de TIC depender predominantemente de terceiros ou de estrutura externa.

Achado 5 – Gestão de serviços de TIC insuficiente para assegurar controle sobre serviços, ativos e incidentes

Critérios

- ITIL 4, prática de gerenciamento do catálogo de serviços: manter fonte única de informações consistentes sobre serviços e ofertas de serviço, disponível para usuários e equipes de suporte;
- COBIT 2019, APO09.02 - Catalogar serviços facilitados por TI: definir, manter e comunicar catálogo de serviços, incluindo serviços prestados, características, requisitos e níveis de serviço esperados;
- ITIL 4, prática de gerenciamento de nível de serviço: definir, acordar, monitorar, avaliar e reportar metas e níveis de serviço alinhados às necessidades das áreas usuárias;
- ITIL 4, prática de gerenciamento de ativos de TI: planejar e gerenciar o ciclo de vida dos ativos de TI, mantendo informações suficientes para apoiar controle, custo, risco, valor e tomada de decisão;
- ITIL 4, prática de gerenciamento de configuração de serviço: assegurar informações precisas e confiáveis sobre itens de configuração e seus relacionamentos com serviços, sistemas e infraestrutura;
- COBIT 2019, BAI10.01 - Estabelecer e manter um modelo de configuração: definir escopo, granularidade, atributos, relacionamentos e responsáveis pela base de configuração;
- ITIL 4, prática de gerenciamento de incidentes: minimizar o impacto negativo dos incidentes por meio da restauração tempestiva da operação normal dos serviços e do registro rastreável do tratamento realizado;
- COBIT 2019, DSS02.02, DSS02.04 e DSS02.07 - Requisições de serviço e incidentes gerenciados: registrar, classificar, priorizar, investigar, diagnosticar, resolver, acompanhar e reportar incidentes e requisições de serviço.

Evidências

- **E1:** A organização declarou “Sim” no subitem a) do item 2201, mas a evidência encaminhada foi considerada insuficiente para comprovar que o catálogo contém as metas definidas para cada serviço (p. ex.: prazos de entrega, horários de serviço e de suporte, bem como pontos de contato para solicitação do serviço, envio de sugestões, esclarecimento de dúvidas e reporte de incidentes);

- Justificativa da avaliação: A avaliação realizada indica que o item não foi atendido. Não foram apresentadas evidências documentais ou de sistemas que detalhem metas definidas para cada serviço, como prazos, horários de atendimento ou pontos de contato. A imagem do dashboard operacional apresentado não contém as informações de catálogo solicitadas. A evidência é insuficiente pela ausência de documento do catálogo de serviços detalhando os parâmetros estabelecidos;
- **E2:** A organização declarou “Sim” no subitem b) do item 2201, mas a evidência encaminhada foi considerada insuficiente para comprovar que o catálogo está atualizado e as informações que nele constam são compatíveis com os Acordos de Níveis de Serviço (ANS) estabelecidos pela área de tecnologia da informação e as áreas de negócio da organização;
 - Justificativa da avaliação: A avaliação realizada indica que o item não foi atendido. Não foram fornecidos o catálogo de serviços, os Acordos de Níveis de Serviço (ANS) formalizados, nem evidências que comprovem a atualização ou a compatibilidade entre ambos. A captura de tela disponibilizada limita-se a métricas operacionais de chamados, sem elementos que permitam verificar a gestão ou a atualização do catálogo frente aos acordos. A evidência é insuficiente pela falta dos documentos estruturantes do processo;
- **E3:** Resposta negativa ao detalhamento c) do item 2201 do Questionário, para verificar se o catálogo é de fácil acesso e está amplamente disponível a seus usuários e às equipes de suporte;
- **E4:** Resposta negativa ao detalhamento d) do item 2201 do Questionário, para verificar se são formalizados ANS contendo metas de nível de serviço acordadas com representantes das áreas de negócio clientes;
- **E5:** A organização declarou “Sim” no subitem a) do item 2203, mas a evidência encaminhada foi considerada insuficiente para comprovar que mantém uma base de dados consolidada e atualizada com as configurações dos serviços e ativos de TI e o relacionamento entre eles;
 - Justificativa da avaliação: A avaliação realizada indica que não há evidência suficiente para comprovar a existência de uma base de dados consolidada e atualizada. O diagrama de topologia constitui apenas uma representação visual estática, sem metadados, datas de atualização ou registros que permitam verificar a abrangência e a consistência da base de ativos e seus

relacionamentos. O material enviado não supre a necessidade de evidenciar a manutenção de um repositório formal de configurações;

- **E6:** Resposta negativa ao detalhamento c) do item 2203 do Questionário, para verificar se o processo de gestão de configuração e ativos está formalizado (a organização instituiu norma interna, guia ou instrumento similar com orientações quanto à execução do processo e definição de responsabilidades);
- **E7:** Resposta negativa ao detalhamento d) do item 2204 do Questionário, para verificar se o(s) processo(s) de gestão de incidentes está(ão) formalizado(s) (a organização instituiu norma interna, guia ou instrumento similar com orientações quanto à execução do processo e definição de responsabilidades).

Situação encontrada

A gestão de serviços de TIC organiza a forma como as soluções e o suporte tecnológico são entregues aos usuários e às áreas demandantes do órgão. Catálogo de serviços, Acordos de Nível de Serviço (ANS), inventário de ativos, gestão de configuração e gestão de incidentes constituem práticas básicas e integradas necessárias para assegurar a transparência operacional, continuidade do negócio, governabilidade financeira, controle de ativos e qualidade de suporte técnico.

Os critérios de boas práticas baseados na ITIL 4 e no COBIT 2019 indicam que a organização deve manter fonte unificada e consistente de informações sobre seu catálogo, estabelecer metas mensuráveis de atendimento, administrar ativamente o ciclo de vida dos ativos tecnológicos, rastrear os relacionamentos lógicos de configuração e registrar de forma sistemática e auditável todas as ocorrências operacionais e incidentes de segurança⁶.

Com base na análise das respostas aos itens 2201, 2203, 2204 e 2504 do questionário aplicado e da avaliação das evidências documentais anexadas, não foi demonstrada adoção suficiente dessas práticas mínimas. A Equipe de Auditoria identificou fragilidades nos seguintes aspectos:

- **Catálogo de serviços de TIC:** a fragilidade ou ausência do catálogo não demonstra aderência à ITIL 4 e ao COBIT 2019 (APO09.02), podendo resultar em prestação reativa, sem transparência ou definição clara das entregas técnicas disponíveis.
- **Níveis mínimos de serviço:** a ausência de parâmetros ou acompanhamento não demonstra aderência aos critérios de catálogo e gerenciamento de nível de serviço (ITIL 4 e COBIT 2019, APO09.02), dificultando a avaliação objetiva da qualidade e tempestividade dos serviços prestados.

⁶ As práticas de gestão de serviços de TIC adotadas como critério baseiam-se em ITIL 4 e COBIT 2019 e abrangem catálogo, níveis de serviço, ativos, configuração e incidentes.

- **Inventário de ativos de TIC:** a fragilidade ou inexistência de inventário não demonstra aderência à prática de gerenciamento de ativos de TI (ITIL 4), reduzindo o controle sobre recursos tecnológicos, licenciamentos de software, custos e riscos associados.
- **Gestão de configuração:** a ausência de mapeamento lógico não demonstra aderência à ITIL 4 e ao COBIT 2019 (BAI10.01), podendo prejudicar a confiabilidade das dependências operacionais entre infraestrutura, sistemas e serviços críticos.
- **Gestão de incidentes de TIC:** a inexecução ou informalidade no processo de atendimento não demonstra aderência à ITIL 4 e ao COBIT 2019 (DSS02.02, DSS02.04 e DSS02.07), dificultando o tratamento padronizado, tempestivo e rastreável de falhas tecnológicas.

Essas situações ensejaram o presente achado e serão detalhadas nas subseções seguintes.

Catálogo de serviços de TIC

O catálogo de serviços de TIC deve constituir fonte única de informações consistentes sobre os serviços prestados, acessível aos usuários e às áreas demandantes. Deve conter informações mínimas sobre os serviços efetivamente prestados, suas características, requisitos, canais de atendimento e níveis esperados de serviço.

A ITIL 4, na prática de gerenciamento do catálogo de serviços, orienta a manutenção de informações consistentes e disponíveis sobre serviços e ofertas de serviço. O COBIT 2019, APO09.02, exige a definição, manutenção e comunicação do catálogo de serviços facilitados por TI.

Da análise das respostas ao item 2201 e da documentação apresentada, verificou-se que a existência de catálogo de serviços de TIC atualizado, acessível aos usuários e com informações mínimas sobre os serviços prestados não se mostrou suficientemente demonstrada, em razão dos seguintes elementos identificados pela Equipe de Auditoria:

- No subitem a) do item 2201, a organização declarou a prática avaliada, mas a evidência foi insuficiente para comprovar que o catálogo contém as metas definidas para cada serviço (p. ex.: prazos de entrega, horários de serviço e de suporte, bem como pontos de contato para solicitação do serviço, envio de sugestões, esclarecimento de dúvidas e reporte de incidentes) (E1);
- No subitem b) do item 2201, a organização declarou a prática avaliada, mas a evidência foi insuficiente para comprovar que o catálogo está atualizado e as informações que nele constam são compatíveis com os Acordos de Níveis de Serviço (ANS) estabelecidos pela área de tecnologia da informação e as áreas de negócio da organização (E2);

- No subitem c) do item 2201, não houve declaração afirmativa quanto à prática avaliada: o catálogo é de fácil acesso e está amplamente disponível a seus usuários e às equipes de suporte (E3).

A inexistência, desatualização ou falta de divulgação do catálogo de serviços dificulta que os usuários conheçam o portfólio de entregas e os canais corretos de atendimento, elevando o risco de prestação de suporte de forma reativa, informal ou pouco transparente.

Níveis de serviço e metas de atendimento

A definição de Acordos de Níveis de Serviço, metas mínimas ou parâmetros equivalentes permite pactuar expectativas, medir desempenho e avaliar a qualidade dos principais serviços de TIC.

A ITIL 4, na prática de gerenciamento de nível de serviço, orienta a definição, monitoramento, avaliação e reporte de metas e níveis de serviço alinhados às necessidades das áreas usuárias. O COBIT 2019, APO09.02, também relaciona o catálogo à comunicação de requisitos e níveis de serviço esperados.

Da análise das respostas ao item 2201 e da documentação apresentada, verificou-se que a definição ou o monitoramento de níveis mínimos de serviço, metas ou parâmetros equivalentes para os serviços de TIC relevantes não se mostrou suficientemente demonstrada, em razão dos seguintes elementos identificados pela Equipe de Auditoria:

- No subitem d) do item 2201, não houve declaração afirmativa quanto à prática avaliada: são formalizados ANS contendo metas de nível de serviço acordadas com representantes das áreas de negócio clientes (E4).

A ausência de níveis mínimos de serviço, metas estruturadas ou parâmetros equivalentes reduz a disponibilidade de bases objetivas para monitorar e avaliar a qualidade, o tempo de resposta e a eficiência dos serviços prestados.

Inventário de ativos de TIC

O inventário de ativos de TIC deve permitir conhecer e controlar equipamentos, servidores, sistemas, *softwares*, licenças, serviços em nuvem, responsáveis e componentes de infraestrutura.

A ITIL 4, na prática de gerenciamento de ativos de TI, orienta o gerenciamento do ciclo de vida dos ativos, mantendo informações suficientes para apoiar controle, custo, risco, valor e tomada de decisão.

Da análise das respostas aos itens 2203 e 2504 e da documentação apresentada, verificou-se que a existência de inventário de ativos de TIC atualizado e abrangente não se mostrou suficientemente demonstrada, em razão dos seguintes elementos identificados pela Equipe de Auditoria:

- No subitem a) do item 2203, a organização declarou a prática avaliada, mas a evidência foi insuficiente para comprovar que mantém uma base de dados consolidada e atualizada com as configurações dos serviços e ativos de TI e o relacionamento entre eles (E5).

A ausência de inventário atualizado e abrangente de ativos de TIC reduz a segurança quanto ao controle sobre equipamentos, sistemas, softwares, licenças, serviços em nuvem e componentes de infraestrutura, elevando riscos relacionados a custos, conformidade, segurança da informação e planejamento de capacidade.

Gestão de configuração

A gestão de configuração deve manter informações precisas e confiáveis sobre itens de configuração relevantes, seus atributos, responsáveis e relacionamentos com ativos, sistemas, infraestrutura e serviços.

A ITIL 4, na prática de gerenciamento de configuração de serviço, orienta assegurar informações confiáveis sobre itens de configuração e seus relacionamentos. O COBIT 2019, BAI10.01, exige a definição de escopo, granularidade, atributos, relacionamentos e responsáveis pela base de configuração.

Da análise das respostas ao item 2203 e da documentação apresentada, verificou-se que a existência de processo mínimo de gestão de configuração com registro de itens relevantes, atributos, responsáveis e relacionamentos entre ativos, sistemas, infraestrutura e serviços não se mostrou suficientemente demonstrada, em razão dos seguintes elementos identificados pela Equipe de Auditoria:

- No subitem a) do item 2203, a organização declarou a prática avaliada, mas a evidência foi insuficiente para comprovar que mantém uma base de dados consolidada e atualizada com as configurações dos serviços e ativos de TI e o relacionamento entre eles (E5);
- No subitem c) do item 2203, não houve declaração afirmativa quanto à prática avaliada: o processo de gestão de configuração e ativos está formalizado (a organização instituiu norma interna, guia ou instrumento similar com orientações quanto à execução do processo e definição de responsabilidades) (E6).

A ausência de registros suficientes de configuração dificulta o mapeamento lógico das dependências entre servidores, bancos de dados, aplicações e serviços finalísticos, podendo reduzir a capacidade de análise de riscos em mudanças operacionais e de tratamento de falhas sistêmicas.

Gestão de incidentes de TIC

A gestão de incidentes de TIC deve definir papéis, responsabilidades, critérios de priorização, escalamento, tratamento, registro sistemático, histórico das ocorrências e análise posterior de incidentes relevantes ou recorrentes.

A ITIL 4, na prática de gerenciamento de incidentes, orienta minimizar impactos negativos por meio da restauração tempestiva da operação normal e do registro rastreável do tratamento realizado. O COBIT 2019, DSS02.02, DSS02.04 e DSS02.07, exige registrar, classificar, priorizar, investigar, diagnosticar, resolver, acompanhar e reportar incidentes e requisições de serviço.

Da análise das respostas ao item 2204 e da documentação apresentada, verificou-se que a existência de processo mínimo de gestão de incidentes de TIC com papéis, critérios de priorização, escalamento, tratamento, registro sistemático e análise posterior de ocorrências relevantes ou recorrentes não se mostrou suficientemente demonstrada, em razão dos seguintes elementos identificados pela Equipe de Auditoria:

- No subitem d) do item 2204, não houve declaração afirmativa quanto à prática avaliada: o(s) processo(s) de gestão de incidentes está(ão) formalizado(s) (a organização instituiu norma interna, guia ou instrumento similar com orientações quanto à execução do processo e definição de responsabilidades) (E7).

O tratamento assistemático ou sem registro centralizado das falhas tecnológicas dificulta o acompanhamento do histórico de incidentes, a identificação de causas raiz e a redução do período de indisponibilidade dos sistemas corporativos.

Conclusão

As fragilidades identificadas na gestão de serviços de TIC reduzem a segurança de que a organização disponha, conforme aplicável ao caso concreto, de práticas suficientes para assegurar eficiência, continuidade, rastreabilidade, qualidade dos serviços prestados e controle sobre ativos, configurações e incidentes.

Em razão das lacunas descritas, são propostas recomendações preliminares voltadas à estruturação e à adequação das práticas de gestão de serviços de TIC efetivamente apontadas neste achado, observados os critérios aplicáveis indicados nas seções anteriores.

Propostas de Encaminhamento

- **Comunicação com Recomendação** para que institua e mantenha atualizado catálogo de serviços de TIC, atentando-se, minimamente, em identificar os serviços efetivamente prestados, seus responsáveis, usuários, condições de acesso e informações necessárias ao atendimento das áreas demandantes;

- **Comunicação com Recomendação** para que defina, pactue e monitore níveis mínimos de serviço ou metas de atendimento para os serviços de TIC mais relevantes, estabelecendo indicadores, responsáveis, periodicidade de medição e forma de comunicação dos resultados;
- **Comunicação com Recomendação** para que estabeleça e mantenha atualizado inventário de ativos de TIC, atentando-se, minimamente, em registrar equipamentos, servidores, sistemas, softwares, licenças, serviços em nuvem, componentes de infraestrutura, responsáveis e informações necessárias ao controle do ciclo de vida dos ativos;
- **Comunicação com Recomendação** para que formalize e execute processo de gestão de configuração, atentando-se, minimamente, em manter base, ferramenta ou registro equivalente com os itens de configuração relevantes, seus responsáveis e os relacionamentos entre ativos, sistemas, infraestrutura e serviços, com atualização periódica e uso das informações no planejamento e acompanhamento de mudanças;
- **Comunicação com Recomendação** para que formalize e execute processo de gestão de incidentes de TIC, atentando-se, minimamente, em definir papéis, responsabilidades, critérios de priorização e escalamento, tratamento de incidentes de serviços e de segurança da informação, registro sistemático e rastreável das ocorrências e análise posterior dos incidentes relevantes ou recorrentes.

Achado 6 – Fragilidades na governança técnica da fase preparatória das contratações de TIC

Critérios

- Art. 11, parágrafo único, da Lei 14.133/2021: responsabilidade da alta administração pela governança das contratações, com processos, estruturas, gestão de riscos e controles internos;
- Art. 18, caput e §1º, incisos I, IV, V, VIII, IX, X e XIII, da Lei 14.133/2021: fase preparatória caracterizada pelo planejamento, compatibilização com o plano de contratações anual e elementos mínimos do estudo técnico preliminar;
- Art. 19, inciso IV, da Lei 14.133/2021: instituição de modelos de minutas de editais, termos de referência, contratos padronizados e demais documentos;
- COBIT 2019, BAI02.04 - Obter aprovação dos requisitos da solução: obter aprovação formal dos requisitos funcionais, técnicos, de segurança e de conformidade antes de prosseguir com a solução;
- COBIT 2019, APO01.05 - Estabelecer papéis e responsabilidades: definir e comunicar papéis e responsabilidades relacionados à informação e à tecnologia;
- COBIT 2019, APO01.09 - Definir e comunicar políticas e procedimentos: manter políticas, procedimentos e orientações para direcionar processos de gestão de TIC;
- Instrução Normativa SGD/ME nº 94, de 23 de dezembro de 2022, art. 1º, § 1º: como referência de boa prática, a aplicação de ritos formais de contratação de TIC pode ser facultada para contratações diretas por dispensa em razão do valor (inciso II do art. 75 da Lei nº 14.133/2021), indicando a possibilidade de fluxos simplificados para aquisições de baixa complexidade ou valor.

Evidências

- **E1:** A organização declarou “Sim” no subitem a) do item 2801, mas a evidência encaminhada foi considerada insuficiente para comprovar que o processo de trabalho para o planejamento das contratações de TI contempla as etapas, as responsabilidades dos atores envolvidos e os artefatos resultantes de cada etapa;
 - Justificativa da avaliação: A avaliação indica que o processo de planejamento para contratações de TI não está definido. A portaria apresentada restringe-se à designação de atribuições de fiscalização, não abordando etapas, papéis ou artefatos da fase de planejamento de contratações. A evidência é insuficiente pois não demonstra os procedimentos de planejamento

requeridos. A lacuna reside na ausência de descrição de fluxos, responsabilidades e etapas do planejamento de TI;

- **E2:** A organização declarou “Sim” no subitem c) do item 2801, mas a evidência encaminhada foi considerada insuficiente para comprovar que o processo de trabalho para a seleção de fornecedores contempla as etapas, as responsabilidades dos atores envolvidos e os artefatos resultantes de cada etapa;
 - Justificativa da avaliação: A avaliação indica que o processo de seleção de fornecedores não está definido. A portaria apresentada não abrange etapas, responsabilidades ou artefatos relativos à fase de seleção. A evidência é insuficiente por tratar exclusivamente de gestão e fiscalização de contratos. A lacuna refere-se à falta de descrição ou normatização do processo de seleção de fornecedores de TI;
- **E3:** A organização declarou “Sim” no subitem d) do item 2801, mas a evidência encaminhada foi considerada insuficiente para comprovar que são disponibilizados artefatos padronizados para a fase de seleção de fornecedores, como minutas, checklists, modelos de edital, pareceres, critérios de julgamento ou documentos equivalentes;
 - Justificativa da avaliação: A avaliação indica que não são disponibilizados artefatos padronizados para a seleção de fornecedores. A documentação enviada não inclui minutas, checklists, editais ou critérios de julgamento. A evidência é insuficiente por não apresentar qualquer artefato dessa natureza. A lacuna consiste na ausência de instrumentos padronizados para a seleção de fornecedores de TI;
- **E4:** A organização declarou “Sim” no subitem e) do item 2801, mas a evidência encaminhada foi considerada insuficiente para comprovar que o processo de trabalho para a gestão e fiscalização de contratos contempla as etapas, as responsabilidades dos atores envolvidos e os artefatos resultantes de cada etapa;
 - Justificativa da avaliação: A avaliação indica que, embora a portaria mencione competências gerais de fiscalização, não há a estruturação de um processo de trabalho por etapas específico para contratos de TI. A evidência é insuficiente pois não demonstra fluxogramas, manuais ou etapas processuais detalhadas com artefatos resultantes para o contexto de TI. A lacuna é a falta de um processo de trabalho formalizado para a gestão e fiscalização de contratos de TI;
- **E5:** A organização declarou “Sim” no subitem g) do item 2801, mas a evidência encaminhada foi considerada insuficiente para comprovar que os processos de

trabalho e os artefatos padronizados estão aderentes às normas legais e infralegais que regem as contratações públicas;

- Justificativa da avaliação: A avaliação indica que a aderência normativa dos processos de trabalho de TI não pode ser verificada. A portaria cita leis gerais de licitações; contudo, a ausência de processos e artefatos específicos de TI impede a análise da aderência à norma para este objeto. A evidência é insuficiente por não demonstrar a aplicação da legislação em fluxos ou instrumentos práticos de TI. A lacuna reside na inexistência de processos de trabalho de TI para confrontar com a legislação;
- **E6:** Resposta negativa ao subitem a) do item 2804 do Questionário, para verificar se as contratações de soluções de TI, independentemente de qual seja a área demandante, são obrigatoriamente submetidas à análise prévia e aprovação técnica da área de gestão de TI;
- **E7:** A organização declarou “Sim” no subitem c) do item 2802, mas a evidência encaminhada foi considerada insuficiente para comprovar que na elaboração do PCA são considerados os demais instrumentos de planejamento da organização;
 - Justificativa da avaliação: A Equipe de Auditoria não identificou elementos que conectem o PCA aos demais instrumentos de planejamento institucional, tais como PPA, LDO ou plano estratégico. A evidência restringe-se aos dados disponibilizados no portal nacional, sem demonstrar o alinhamento ou integração com outros instrumentos. Ausência de comprovação documental da integração do PCA com o planejamento institucional;
- **E8:** A organização declarou “Sim” no subitem d) do item 2802, mas a evidência encaminhada foi considerada insuficiente para comprovar que o PCA fundamenta a proposta orçamentária da organização;
 - Justificativa da avaliação: A Equipe de Auditoria não encontrou evidências que demonstrem a correlação entre o PCA e a proposta orçamentária. Embora o portal exiba o valor total estimado, não há registro da fundamentação orçamentária decorrente deste plano. Ausência de documento, nota técnica ou memória de cálculo que vincule o PCA à proposta orçamentária.

Situação encontrada

As contratações de TIC devem observar governança técnica, planejamento prévio proporcional à complexidade do objeto, participação da área de tecnologia quando cabível e critérios objetivos para recebimento e mensuração de resultados. A complexidade dos ativos

de tecnologia, as exigências de conformidade legal, incluindo LGPD quando aplicável, e a dependência das atividades finalísticas em relação aos serviços de TIC demandam controles compatíveis com a relevância, o risco e o valor da contratação.

Os critérios previstos na Lei 14.133/2021, na Lei 13.709/2018 (LGPD) e nos objetivos do COBIT 2019 disciplinam que a alta administração responde pela governança das contratações, que a fase preparatória deve ser instruída com planejamento compatível com o objeto e que os Termos de Referência (TR), projetos básicos, contratos ou instrumentos equivalentes devem conter requisitos, modelos de execução, critérios de medição e parâmetros de acompanhamento proporcionais à natureza da contratação⁷.

Com base na análise das respostas aos itens 2801, 2804, 2102 e 2802 do questionário aplicado e da avaliação das evidências documentais anexadas, não foi demonstrado atendimento suficiente das contratações de TIC da organização a essas diretrizes. A Equipe de Auditoria identificou fragilidades nos seguintes aspectos:

- **Processo de contratação de TIC:** a fragilidade ou ausência de fluxo padronizado contraria a governança de contratações (Lei 14.133/2021, art. 11/art. 19, IV) e o COBIT 2019 (APO01.09), acarretando indefinição de papéis, ritos processuais e prazos internos.
- **Aprovação técnica de TIC:** a falta de avaliação prévia pela área técnica, quando necessária, contraria a governança institucional (COBIT 2019, BAI02.04 e APO01.05), favorecendo aquisições de soluções desalinhadas do ambiente tecnológico existente.
- **Alinhamento ao planejamento:** a ausência de alinhamento demonstrado ao planejamento de TIC, ao plano de contratações ou à proposta orçamentária não demonstra aderência à Lei 14.133/2021 (arts. 11 e 18), podendo resultar em aquisições reativas ou sem lastro orçamentário adequado.

Essas situações ensejaram o presente achado e serão detalhadas nas subseções seguintes.

Processo formal e padronizado para contratações de TIC

O processo de contratação de TIC deve estabelecer fluxo, etapas, papéis, responsabilidades, modelos mínimos de artefatos, manuais, checklists ou orientações internas. Esses elementos reduzem improvisação, aumentam padronização e permitem controle sobre a qualidade da instrução processual.

O art. 11, parágrafo único, da Lei 14.133/2021 atribui à alta administração responsabilidade pela governança das contratações, com processos, estruturas, gestão de

⁷ Os critérios de contratações de TIC combinam requisitos legais da Lei 14.133/2021, requisitos de segurança e proteção de dados da LGPD e boas práticas do COBIT 2019 sobre requisitos, papéis, procedimentos, contratos e desempenho de fornecedores.

riscos e controles internos. O art. 19, inciso IV, prevê a instituição de modelos de documentos padronizados, e o COBIT 2019, APO01.09, orienta a definição e comunicação de políticas e procedimentos.

Da análise das respostas ao item 2801 e da documentação apresentada, verificou-se que a existência de processo formal e padronizado para contratações de TIC, com fluxo, etapas, papéis, responsabilidades, instâncias de aprovação e modelos de artefatos proporcionais ao porte e aos riscos das contratações, não se mostrou suficientemente demonstrada, em razão dos seguintes elementos identificados pela Equipe de Auditoria:

- No subitem a) do item 2801, a organização declarou a prática avaliada, mas a evidência foi insuficiente para comprovar que o processo de trabalho para o planejamento das contratações de TI contempla as etapas, as responsabilidades dos atores envolvidos e os artefatos resultantes de cada etapa (E1);
- No subitem c) do item 2801, a organização declarou a prática avaliada, mas a evidência foi insuficiente para comprovar que o processo de trabalho para a seleção de fornecedores contempla as etapas, as responsabilidades dos atores envolvidos e os artefatos resultantes de cada etapa (E2);
- No subitem d) do item 2801, a organização declarou a prática avaliada, mas a evidência foi insuficiente para comprovar que são disponibilizados artefatos padronizados para a fase de seleção de fornecedores, como minutas, checklists, modelos de edital, pareceres, critérios de julgamento ou documentos equivalentes (E3);
- No subitem e) do item 2801, a organização declarou a prática avaliada, mas a evidência foi insuficiente para comprovar que o processo de trabalho para a gestão e fiscalização de contratos contempla as etapas, as responsabilidades dos atores envolvidos e os artefatos resultantes de cada etapa (E4);
- No subitem g) do item 2801, a organização declarou a prática avaliada, mas a evidência foi insuficiente para comprovar que os processos de trabalho e os artefatos padronizados estão aderentes às normas legais e infralegais que regem as contratações públicas (E5).

A ausência de fluxo processual regulamentado e de modelos padronizados reduz a segurança quanto à conformidade das contratações de TIC e eleva o risco de atrasos processuais, indefinição de papéis e inconsistências na elaboração dos documentos da fase preparatória.

Análise prévia e aprovação técnica da área de TIC

As contratações de TIC devem ser submetidas à análise prévia e aprovação técnica da área de TIC, inclusive quando demandadas por outras áreas da organização. Essa

análise é necessária para verificar compatibilidade técnica, segurança, integração com o ambiente existente, riscos e aderência a padrões institucionais.

O COBIT 2019, BAI02.04, orienta a obtenção de aprovação formal dos requisitos funcionais, técnicos, de segurança e de conformidade antes de prosseguir com a solução. O COBIT 2019, APO01.05, reforça a definição de papéis e responsabilidades relacionados à informação e à tecnologia. De forma complementar, o art. 1º, § 1º, da Instrução Normativa SGD/ME nº 94/2022, adotado como referência de boa prática, aponta a possibilidade de facultar a aplicação de ritos formais para contratações diretas por dispensa em razão do valor (inciso II do art. 75 da Lei nº 14.133/2021), indicando que os controles e pareceres podem ser proporcionais à relevância estratégica, complexidade e valor da aquisição.

Da análise das respostas ao item 2804 e da documentação apresentada, verificou-se que a submissão das contratações de TIC à análise prévia ou aprovação técnica da área de TIC, inclusive quando demandadas por outras áreas, não se mostrou suficientemente demonstrada, em razão dos seguintes elementos identificados pela Equipe de Auditoria:

- No subitem a) do item 2804, não houve declaração afirmativa quanto à prática avaliada: as contratações de soluções de TI, independentemente de qual seja a área demandante, são obrigatoriamente submetidas à análise prévia e aprovação técnica da área de gestão de TI (E6).

A ausência de análise prévia ou aprovação técnica da área de TIC reduz a segurança de que as soluções contratadas sejam compatíveis com o ambiente tecnológico existente, com os requisitos institucionais e com os controles mínimos de segurança da informação, observada a proporcionalidade em relação à complexidade, ao risco e ao valor da contratação.

Alinhamento ao planejamento, plano de contratações e proposta orçamentária

As contratações de TIC devem estar vinculadas ao planejamento de TIC, ao plano de contratações e à proposta orçamentária. Essa vinculação demonstra que a contratação decorre de prioridade definida, possui respaldo orçamentário e contribui para objetivos institucionais.

O art. 18 da Lei 14.133/2021 prevê a compatibilização da contratação com o plano de contratações anual e o planejamento da Administração. O art. 11 também reforça a responsabilidade da alta administração pela governança das contratações.

Da análise das respostas aos itens 2102, 2802 e 2804 e da documentação apresentada, verificou-se que o alinhamento das contratações de TIC ao planejamento de TIC, ao plano de contratações ou à proposta orçamentária não se mostrou suficientemente demonstrado, em razão dos seguintes elementos identificados pela Equipe de Auditoria:

- No subitem c) do item 2802, a organização declarou a prática avaliada, mas a evidência foi insuficiente para comprovar que na elaboração do PCA são considerados os demais instrumentos de planejamento da organização (E7);
- No subitem d) do item 2802, a organização declarou a prática avaliada, mas a evidência foi insuficiente para comprovar que o PCA fundamenta a proposta orçamentária da organização (E8).

A ausência de alinhamento das contratações de TIC ao planejamento de TIC, ao plano de contratações ou à proposta orçamentária eleva o risco de fragmentação de despesas, contratações reativas ou insuficientemente priorizadas e uso pouco eficiente dos recursos orçamentários.

Conclusão

As fragilidades evidenciadas na fase preparatória das contratações de TIC reduzem a segurança de que a organização disponha de controles suficientes para assegurar, conforme aplicável ao caso concreto, processo formal de contratação, participação técnica da área de TIC, alinhamento ao planejamento e adequada instrução dos processos. Essas fragilidades elevam o risco de contratações insuficientemente fundamentadas, pouco rastreáveis ou desalinhadas às necessidades institucionais, à complexidade e aos riscos das soluções de TIC pretendidas.

Em razão das lacunas descritas, são propostas recomendações preliminares voltadas à estruturação e à adequação dos aspectos da fase preparatória das contratações de TIC efetivamente apontados neste achado, observados os critérios aplicáveis indicados nas seções anteriores.

Propostas de Encaminhamento

- **Comunicação com Recomendação** para que formalize e padronize o processo de contratação de TIC, compatível com o porte, a complexidade e os riscos das contratações da organização, atentando-se, minimamente, em definir fluxo, etapas, papéis, responsabilidades, instâncias de aprovação e modelos de artefatos, manuais, listas de verificação ou orientações internas aplicáveis;
- **Comunicação com Recomendação** para que estabeleça a submissão das contratações de TIC à análise prévia da área de TIC, inclusive quando demandadas por outras áreas, de modo a verificar a compatibilidade da solução com os padrões tecnológicos, os requisitos institucionais, a segurança da informação e a arquitetura existente, admitindo fluxos simplificados para contratações de baixa complexidade ou baixo valor, desde que preservada análise técnica mínima compatível com o risco da contratação;

- **Comunicação com Recomendação** para que integre as contratações de TIC ao planejamento de TIC, ao plano de contratações e à proposta orçamentária, atentando-se, minimamente, em registrar a necessidade atendida, a prioridade, a disponibilidade de recursos e a justificativa das situações excepcionais.

SIGILOSO

4. Plano de ação

Para facilitar o atendimento das propostas constantes da Seção 3, a Equipe de Auditoria elaborou modelo preliminar de plano de ação contendo os encaminhamentos propostos à organização. O quadro não antecipa decisão final desta Corte de Contas e poderá ser revisto após a análise dos comentários do gestor.

Cumpra registrar que, em conformidade com o art. 4º, incisos I e II, da Deliberação TCE-RJ nº 346/2024, cabe à unidade jurisdicionada avaliar a conveniência e a oportunidade de implementar as recomendações. Ressalta-se, contudo, que a eventual decisão pela não aderência deve ser motivada: o gestor deve apresentar justificativa formal que demonstre, à luz das circunstâncias do caso concreto, as razões da decisão e, quando cabível, as medidas alternativas adotadas para tratar a situação que ensejou a recomendação.

Tabela 8 - Plano de ação contendo os encaminhamentos preliminarmente propostos

Achado	Medida proposta	Avaliação de		
		Viabilidade	Quem?	Quando?
2	estabeleça modelo básico de governança e gestão de TIC, atentando-se, minimamente, em definir papéis e responsabilidades, objetivos, indicadores, metas e forma de acompanhamento periódico do desempenho da TIC pela alta administração			
2	institua formalmente Comitê de TIC ou instância equivalente, compatível com o porte e a estrutura decisória da organização, atentando-se, minimamente, em definir sua composição, competências, periodicidade de reuniões, forma de registro das deliberações e acompanhamento dos encaminhamentos			
3	submeta o plano de TIC à aprovação formal do dirigente máximo ou de dirigente ou colegiado integrante da alta administração, mantendo registro do respectivo ato de aprovação			
3	integre o plano de TIC à proposta orçamentária, ao plano de contratações e às contratações de TIC, atentando-se, minimamente, em priorizar as demandas conforme sua relevância, seus riscos e a capacidade de execução da organização			
4	estime e mantenha atualizado o quantitativo necessário de pessoal de TIC e segurança da informação, considerando o porte e a complexidade da organização, os serviços críticos, os sistemas mantidos, as contratações vigentes e os riscos relevantes			

Achado	Medida proposta	Avaliação de		
		Viabilidade	Quem?	Quando?
4	avale a necessidade de instituir cargos, funções, gratificações, perfis ou ocupações específicas de TIC e segurança da informação e adote a solução compatível com as necessidades institucionais e a capacidade administrativa da organização			
4	defina perfis profissionais mínimos para gestores e colaboradores de TIC e segurança da informação, atentando-se, minimamente, em estabelecer conhecimentos, habilidades, experiência e responsabilidades requeridos e utilizar esses perfis na seleção e designação dos responsáveis			
4	realize diagnóstico periódico das lacunas de competências dos gestores e colaboradores de TIC e segurança da informação e estabeleça plano de tratamento, contemplando, conforme a necessidade, capacitação, realocação, provimento, apoio especializado, compartilhamento de estrutura ou contratação com transferência de conhecimento			
4	avale o modelo de operação de TIC e adote medidas proporcionais para assegurar capacidade interna suficiente de coordenação, planejamento, aprovação técnica, fiscalização contratual e retenção de conhecimento, especialmente quando a execução das atividades de TIC depender predominantemente de terceiros ou de estrutura externa			
5	institua e mantenha atualizado catálogo de serviços de TIC, atentando-se, minimamente, em identificar os serviços efetivamente prestados, seus responsáveis, usuários, condições de acesso e informações necessárias ao atendimento das áreas demandantes			
5	defina, pactue e monitore níveis mínimos de serviço ou metas de atendimento para os serviços de TIC mais relevantes, estabelecendo indicadores, responsáveis, periodicidade de medição e forma de comunicação dos resultados			
5	estabeleça e mantenha atualizado inventário de ativos de TIC, atentando-se, minimamente, em registrar equipamentos, servidores, sistemas, softwares, licenças, serviços em nuvem, componentes de infraestrutura, responsáveis e informações necessárias ao controle do ciclo de vida dos ativos			

Achado	Medida proposta	Avaliação de		
		Viabilidade	Quem?	Quando?
5	formalize e execute processo de gestão de configuração, atentando-se, minimamente, em manter base, ferramenta ou registro equivalente com os itens de configuração relevantes, seus responsáveis e os relacionamentos entre ativos, sistemas, infraestrutura e serviços, com atualização periódica e uso das informações no planejamento e acompanhamento de mudanças			
5	formalize e execute processo de gestão de incidentes de TIC, atentando-se, minimamente, em definir papéis, responsabilidades, critérios de priorização e escalamento, tratamento de incidentes de serviços e de segurança da informação, registro sistemático e rastreável das ocorrências e análise posterior dos incidentes relevantes ou recorrentes			
6	formalize e padronize o processo de contratação de TIC, compatível com o porte, a complexidade e os riscos das contratações da organização, atentando-se, minimamente, em definir fluxo, etapas, papéis, responsabilidades, instâncias de aprovação e modelos de artefatos, manuais, listas de verificação ou orientações internas aplicáveis			
6	estabeleça a submissão das contratações de TIC à análise prévia da área de TIC, inclusive quando demandadas por outras áreas, de modo a verificar a compatibilidade da solução com os padrões tecnológicos, os requisitos institucionais, a segurança da informação e a arquitetura existente, admitindo fluxos simplificados para contratações de baixa complexidade ou baixo valor, desde que preservada análise técnica mínima compatível com o risco da contratação			
6	integre as contratações de TIC ao planejamento de TIC, ao plano de contratações e à proposta orçamentária, atentando-se, minimamente, em registrar a necessidade atendida, a prioridade, a disponibilidade de recursos e a justificativa das situações excepcionais			

(Fonte: elaboração própria)

Apêndice A. Comparabilidade com o ciclo anterior (iGovTI 2023 vs. iGovTI 2026)

A estrutura de 2026 preservou a escala de 0 a 1, as categorias de resposta e as quatro faixas de maturidade empregadas em 2023, mas alterou de forma relevante a composição dos agregados e seus pesos. As principais diferenças estão sintetizadas na Tabela 9.

Tabela 9 - Principais diferenças entre as estruturas do iGovTI 2023 e do iGovTI 2026

Aspecto	iGovTI 2023	iGovTI 2026	Implicação analítica
Composição do índice final	Governança de TIC e Gestão de TIC com pesos iguais de 0,50.	Governança de TIC com peso 0,4777 e Gestão de TIC com peso 0,5223.	A gestão passou a ter participação ligeiramente superior no índice final.
Governança de TIC	Agregação hierárquica de ModeloTI, MonitorAvaliaTI e ResultadoTI.	Agregação direta de quatro práticas relativas ao modelo de gestão, monitoramento, auditoria interna e simplificação de serviços públicos.	O componente tornou-se mais direto e incorporou práticas com escopo distinto da estrutura anterior.
Gestão de TIC	Agregação de Planejamento de TIC, Pessoas e Processos de TIC; este último reunia serviços, níveis de serviço, riscos, segurança, software, projetos e contratos.	Agregação direta das seis dimensões de Gestão de TIC descritas neste relatório.	O índice passou a evidenciar separadamente seis capacidades operacionais e de segurança.
Pessoas e contratações	Pessoas e contratações de TIC integravam o cálculo da Gestão de TIC.	Não integram a árvore de cálculo do iGovTI 2026, embora continuem relevantes para o diagnóstico e para a auditoria.	Mudanças nessas matérias não explicam diretamente a variação do índice de 2026.
Serviços, software e projetos	Serviços e níveis de serviço eram agregados distintos; software e projetos integravam Processos de TIC.	Serviços foram consolidados na dimensão Gestão de Serviços de TIC; software e projetos foram reunidos na dimensão Gestão de Soluções de TIC.	A leitura deve considerar a nova delimitação conceitual dos componentes.

(Fonte: elaboração própria)

Em razão dessas alterações, a diferença entre os valores nominais de 2023 e 2026 não deve ser interpretada automaticamente como evolução ou retrocesso institucional. Uma análise temporal válida exige a harmonização das questões e dos agregados comparáveis, além da consideração de mudanças de escopo, pesos, respondentes e qualidade das evidências.

Para viabilizar a análise longitudinal, foram elaboradas estruturas ajustadas comparáveis para 2023 e 2026, com a manutenção apenas das práticas passíveis de correspondência entre os instrumentos e a aplicação de uma estrutura comum de agregação. Após a normalização das siglas e a validação das correspondências institucionais, foram identificadas 69 organizações presentes nos dois ciclos, equivalentes a 60,5% das organizações com respostas completas em 2026. A comparação individual foi apresentada somente para esse conjunto pareado.

Os resultados ajustados comparáveis têm finalidade exclusivamente analítica. Eles não substituem os índices oficiais de cada ciclo, não eliminam integralmente os efeitos de alterações de respondentes ou de contexto institucional e não constituem, isoladamente, evidência de conformidade ou de inconformidade.

Apêndice B. Ajustes nas respostas declaradas

A Equipe de Auditoria, em busca da melhor representação do cenário atual de governança e gestão de TIC, ajustou resposta(s) declarada(s) pela organização **RIOPREVIDENCIA** ao questionário iGovTI 2026.

Para tanto, foram utilizadas as justificativas e evidências fornecidas pelo jurisdicionado quando do envio das respostas ao questionário. Ressalta-se que a verificação dessa documentação foi realizada nos termos dos procedimentos definidos para a fiscalização, de modo que nem todas as evidências encaminhadas foram, necessariamente, objeto de análise exaustiva pela Equipe de Auditoria.

Seguem as alterações realizadas após a avaliação das respostas e da amostra de evidências, bem como as justificativas apresentadas pela Equipe:

Tabela 10 - Relação de respostas ajustadas pela Equipe após validação

Questão	Resposta original	Resposta ajustada	Justificativa
q0103[E]	Sim	Não	Embora o Regimento Interno preveja a especificação de aquisições de hardware e software pela GERTIC, não há previsão expressa de competência para a gestão, fiscalização e acompanhamento de contratos ou fornecedores de serviços de tecnologia. As funções de gestão contratual geral são atribuídas a outras unidades, sem especificidade para a área de TI. A ausência desta competência formalizada constitui lacuna no exercício da gestão de contratos e fornecedores de tecnologia.
q1001	Adota parcialmente.	Não adota.	A avaliação da Equipe de Auditoria indica que a evidência apresentada é insuficiente para comprovar a existência de um modelo de gestão de TI instituído pela alta administração. O documento limita-se a apresentar um painel operacional com dados de atendimento de chamados, sem conter políticas, normas, organogramas ou atos normativos que formalizem o modelo de gestão. A evidência carece de elementos que demonstrem a instituição formal do modelo e a sua aprovação pelos níveis hierárquicos superiores.
q1001ext[C]	Sim	Não	A avaliação da Equipe de Auditoria indica que não há comprovação da definição formal de papéis e responsabilidades para a área de TI. Embora o painel relacione técnicos a demandas, tal informação é meramente operacional e não equivale a um documento normativo, regimento interno ou matriz de responsabilidades que estabeleça as atribuições dos cargos. É necessária a apresentação de documento institucional que defina formalmente a estrutura de papéis e responsabilidades.

Questão	Resposta original	Resposta ajustada	Justificativa
q1001ext[G]	Sim	Não	A avaliação da Equipe de Auditoria indica que o painel apresentado não constitui diretrizes para avaliação de desempenho dos serviços de TI. O documento exhibe indicadores quantitativos de monitoramento, mas carece de normas, critérios, periodicidade ou metodologia aprovada para a avaliação do desempenho. A evidência é insuficiente por não apresentar o documento normativo que formalize os parâmetros e procedimentos para essa avaliação.
q1001ext[H]	Sim	Não	A avaliação da Equipe de Auditoria indica que não foram apresentados objetivos, indicadores ou metas formalmente estabelecidos para a gestão de TI. A evidência consiste apenas em um painel de monitoramento operacional, sem registro documental que formalize metas quantitativas, indicadores estratégicos ou objetivos de gestão aprovados pela organização. É necessária a apresentação de instrumento formal contendo o planejamento e a aprovação desses elementos.
q1002	Adota em maior parte ou totalmente.	Não adota.	A avaliação realizada indica que a organização não atende ao requisito. Embora existam painéis de monitoramento operacional, não há evidências que demonstrem a atuação ou o acompanhamento da alta administração sobre os dados de desempenho de TI. A análise crítica revela a ausência de registros de reuniões, atas ou relatórios executivos de prestação de contas voltados à liderança. A lacuna consiste na inexistência de mecanismos formais de governança que vinculem o monitoramento operacional à supervisão pela alta gestão.
q1002ext[A]	Sim	Não	A avaliação realizada indica que o item não foi atendido. Embora existam sistemas de coleta de dados em operação, não foram apresentados documentos normativos, manuais ou atos administrativos que definam formalmente as rotinas de monitoramento. A análise crítica aponta que capturas de tela isoladas são insuficientes para comprovar a existência de processos de trabalho estabelecidos. A lacuna reside na ausência de normatização formal dos procedimentos de acompanhamento.
q1002ext[B]	Sim	Não	A avaliação realizada indica que o item não foi atendido. A evidência apresenta uma relação de projetos e seu percentual de execução, porém não demonstra o acompanhamento do alcance das metas estratégicas estabelecidas para a TI. A análise crítica observa que o controle apresentado é de natureza operacional e cronológica, sem correlação com indicadores de desempenho ou resultados pactuados. A lacuna consiste na ausência de evidências de monitoramento do alcance de metas formalmente estabelecidas em planos vigentes.

Questão	Resposta original	Resposta ajustada	Justificativa
q1002ext[D]	Sim	Não	A avaliação realizada indica que o item não foi atendido. Embora existam painéis de monitoramento operacional, não há evidências de que relatórios de desempenho sejam disponibilizados ou reportados à liderança da organização. A análise crítica indica que os dashboards apresentados possuem natureza técnica e não foram vinculados a um fluxo formal de prestação de contas aos dirigentes. A lacuna consiste na ausência de relatórios executivos ou evidências de disseminação dos indicadores para a alta administração.
q2102ext[A]	Sim	Não	A evidência apresentada é insuficiente para demonstrar o atendimento ao critério. Embora o plano cite a criação do Comitê PEDTIC por meio da Portaria nº 505/2023, não foi apresentado ato formal, despacho ou documento assinado que comprove a aprovação final do plano pelo dirigente máximo ou por colegiado da alta administração. Ausência de evidência documental da aprovação oficial do PEDTIC 2024.
q2102ext[B]	Sim	Não	O critério não foi atendido. Não foram apresentadas evidências de publicação do PEDTIC 2024 no portal da organização na internet. O endereço eletrônico citado no documento refere-se apenas ao Planejamento Estratégico Institucional (PEI) e não ao plano de tecnologia da informação.
q2201	Adota em maior parte ou totalmente.	Não adota.	A avaliação realizada indica que o item não foi atendido. A evidência consiste apenas em um dashboard operacional de gestão de chamados do sistema GLPI, sem demonstrar a existência de um catálogo de serviços de TI organizado. A ausência de documento, portal ou sistema que relacione os serviços prestados, bem como de Acordos de Nível de Serviço (ANS) formalizados, inviabiliza a verificação do critério. A evidência é insuficiente por tratar apenas de monitoramento de volume de tickets e não da gestão de catálogo de serviços.
q2201ext[A]	Sim	Não	A avaliação realizada indica que o item não foi atendido. Não foram apresentadas evidências documentais ou de sistemas que detalhem metas definidas para cada serviço, como prazos, horários de atendimento ou pontos de contato. A imagem do dashboard operacional apresentado não contém as informações de catálogo solicitadas. A evidência é insuficiente pela ausência de documento do catálogo de serviços detalhando os parâmetros estabelecidos.

Questão	Resposta original	Resposta ajustada	Justificativa
q2201ext[B]	Sim	Não	A avaliação realizada indica que o item não foi atendido. Não foram fornecidos o catálogo de serviços, os Acordos de Níveis de Serviço (ANS) formalizados, nem evidências que comprovem a atualização ou a compatibilidade entre ambos. A captura de tela disponibilizada limita-se a métricas operacionais de chamados, sem elementos que permitam verificar a gestão ou a atualização do catálogo frente aos acordos. A evidência é insuficiente pela falta dos documentos estruturantes do processo.
q2203	Adota em maior parte ou totalmente.	Não adota.	A avaliação realizada indica que a evidência apresentada é insuficiente para demonstrar a execução de um processo estruturado de gestão de configuração e ativos. O documento fornecido limita-se a um diagrama estático de topologia, o qual, embora apresente alguns componentes de rede, não comprova a existência de procedimentos, responsabilidades ou a manutenção contínua do inventário. A evidência é incapaz de sustentar a afirmação de que a organização executa efetivamente o processo de gestão de ativos e serviços de TI.
q2203ext[A]	Sim	Não	A avaliação realizada indica que não há evidência suficiente para comprovar a existência de uma base de dados consolidada e atualizada. O diagrama de topologia constitui apenas uma representação visual estática, sem metadados, datas de atualização ou registros que permitam verificar a abrangência e a consistência da base de ativos e seus relacionamentos. O material enviado não supre a necessidade de evidenciar a manutenção de um repositório formal de configurações.
q2203ext[B]	Sim	Não	A avaliação realizada indica que não há evidência de que a base de configurações seja utilizada no processo de gestão de mudanças. O diagrama fornecido não apresenta vínculos, registros ou fluxos que associem os ativos mapeados a solicitações de mudança, análises de impacto ou acompanhamento de alterações na infraestrutura. A ausência de elementos que integrem a base de dados ao processo de mudanças impede a conformidade com o critério.
q2204ext[C]	Sim	Não	Não foram apresentadas evidências que comprovem a existência ou a utilização de uma base de conhecimento para registro de erros conhecidos e problemas recorrentes. Embora a política preveja o registro de incidentes, não há evidência de repositório, catálogo ou sistema de 'conhecimento' (KEDB) que auxilie a equipe na resolução eficiente de problemas. A ausência de evidência documental específica torna o item não conforme.

Questão	Resposta original	Resposta ajustada	Justificativa
q2501ext[C]	Sim	Não	O item apresenta não conformidade. Embora o inventário utilize o campo “Finalidade” para descrever as funções dos ativos, como o processamento de DNS ou soluções internas, não há classificação formal ou explícita do nível de criticidade dessas informações. A ausência de parâmetros que qualifiquem o impacto das informações limita a identificação efetiva de sua criticidade.
q2504ext[F]	Sim	Não	Embora os painéis listem administradores, não foram apresentadas evidências de controles compensatórios específicos, como autenticação multifator, gestão de acessos privilegiados ou segregação de funções. A evidência é insuficiente para comprovar a existência desses controles.
q2504ext[J]	Sim	Não	Não foram apresentadas evidências documentais ou registros de sistemas que comprovem a realização de backups ou a execução de testes de recuperação das informações. A evidência é insuficiente por ausência de qualquer comprovante sobre o tema.
q2504ext[K]	Sim	Não	A evidência apresentada mostra monitoramento contínuo de vulnerabilidades e risco, mas não comprova a execução periódica de testes de segurança (varreduras ou testes de penetração) com os respectivos relatórios. A evidência é insuficiente por não conter resultados de testes.
q2702	Adota em maior parte ou totalmente.	Não adota.	A evidência apresentada, intitulada ‘planilha_gestao_pessoas_aderente.xlsx’, compreende um levantamento de competências técnicas atuais dos colaboradores, e não a definição de perfis profissionais desejados para as ocupações. O documento lista o nível de proficiência individual de servidores e terceirizados, sem estabelecer requisitos, atribuições ou descrições de cargo almejadas. A ausência de documentos formais que definam os perfis profissionais por ocupação ou grupo de colaboradores torna a evidência insuficiente para o atendimento do critério.
q2702ext[A]	Sim	Não	A documentação fornecida restringe-se a uma matriz de habilidades técnicas de indivíduos, não contendo a definição das responsabilidades e atribuições inerentes às ocupações ou grupos de ocupações. Não foram apresentados normativos, descrições de cargos ou documentos institucionais que estabeleçam o escopo de atuação. Adicionalmente, inexistência de evidência que comprove a publicação formal dessas responsabilidades.

Questão	Resposta original	Resposta ajustada	Justificativa
q2702ext[B]	Sim	Não	Considerando que as responsabilidades e atribuições das ocupações não foram definidas ou documentadas, não há base para a verificação de revisões periódicas. A planilha enviada não contém metadados como datas de revisão, históricos de atualização, controle de versão ou normativos que indiquem um fluxo de revisão periódica. Consequentemente, não há evidência de um processo de revisão ou da publicação de versões atualizadas.
q2702ext[C]	Sim	Não	Embora a evidência relacione competências técnicas e habilidades em uma matriz, estas refletem o nível atual dos profissionais e não os requisitos obrigatórios ou desejados para os cargos. O documento carece de menção a requerimentos de ordem legal, como formação mínima, certificações obrigatórias ou habilitações exigidas para o exercício das funções. A ausência de uma definição de requisitos (legais e de competência) impede que o documento seja validado como o perfil profissional exigido.
q2704	Adota em maior parte ou totalmente.	Não adota.	A avaliação da Equipe de Auditoria indica a não conformidade, pois a evidência apresentada não demonstra que a escolha dos gestores de tecnologia da informação e segurança da informação ocorre segundo perfis profissionais previamente definidos e documentados. Embora o Regimento Interno do Rioprevidência (Portaria RIOPREV/PRESI nº 590/2025) detalhe a estrutura organizacional e as competências da Gerência de Tecnologia da Informação e Comunicações (GERTIC), não há o estabelecimento de requisitos técnicos, perfis de competência ou procedimentos estruturados para a seleção desses ocupantes. A evidência é insuficiente por não apresentar normativos ou documentos que formalizem os critérios, métodos ou ferramentas de seleção aplicados a tais cargos.
q2704ext[B]	Sim	Não	A avaliação da Equipe de Auditoria indica a não conformidade, visto que a documentação apresentada não comprova a seleção de gestores com base em perfil profissional previamente definido e compatível com a função. O Regimento Interno limita-se a descrever a estrutura e competências das unidades, sem estabelecer ou referenciar requisitos profissionais específicos ou processos de seleção para os cargos de gestão de TI e segurança da informação. A evidência carece de documentos que comprovem a existência de perfis profissionais, critérios de compatibilidade e o registro do procedimento de escolha fundamentado em critérios objetivos.

Questão	Resposta original	Resposta ajustada	Justificativa
q2708[A]	Sim	Não	A evidência apresentada é insuficiente para atestar a existência de cargos específicos em tecnologia da informação. O organograma demonstra apenas a estrutura organizacional e as unidades administrativas, não comprovando a criação legal ou normativa de cargos efetivos específicos para a área. A existência de unidades organizacionais não equivale, por si só, à definição de cargos em plano de carreira. Falta a apresentação de ato normativo, lei, plano de cargos ou edital que oficialize a criação desses cargos.
q2708[C]	Sim	Não	A evidência é insuficiente para comprovar a existência de cargos específicos em segurança da informação. Embora o organograma contemple uma 'Coordenadoria DPO', esta unidade é voltada à proteção de dados pessoais (LGPD) e não se confunde com a área de segurança da informação em sentido amplo. Não há registro de cargo formalmente estruturado ou denominado com atribuições específicas de segurança da informação. Falta a comprovação documental de cargo criado com esse escopo técnico.
q2708[D]	Sim	Não	A evidência não demonstra a existência de funções específicas em segurança da informação na estrutura organizacional. A 'Coordenadoria DPO' presente no organograma está associada à conformidade e proteção de dados pessoais, não constituindo função atribuída à segurança da informação em sentido técnico ou operacional. Não há unidade ou função que remeta explicitamente à segurança da informação ou segurança cibernética. Falta a indicação de unidade ou função formalmente designada para tal finalidade.
q2801	Adota em maior parte ou totalmente.	Não adota.	A avaliação indica que os processos de trabalho para contratações de TI não estão definidos. A documentação apresentada (Portaria Rioprev nº 466/2023) limita-se a instituir competências para a gestão e fiscalização de contratos em geral, sem contemplar o ciclo completo das contratações de TI. A evidência é insuficiente por não apresentar fluxos, manuais ou artefatos específicos voltados ao planejamento e seleção de fornecedores de tecnologia. A lacuna consiste na ausência de normatização e de artefatos padronizados voltados para as fases de planejamento e seleção de contratações de TI.

Questão	Resposta original	Resposta ajustada	Justificativa
q2801ext[A]	Sim	Não	A avaliação indica que o processo de planejamento para contratações de TI não está definido. A portaria apresentada restringe-se à designação de atribuições de fiscalização, não abordando etapas, papéis ou artefatos da fase de planejamento de contratações. A evidência é insuficiente pois não demonstra os procedimentos de planejamento requeridos. A lacuna reside na ausência de descrição de fluxos, responsabilidades e etapas do planejamento de TI.
q2801ext[B]	Sim	Não	A avaliação indica que não são disponibilizados artefatos padronizados para a fase de planejamento. O documento enviado trata apenas de competências de fiscalização, não oferecendo modelos de DFD, ETP, TR ou Matriz de Riscos. A evidência é insuficiente por não conter tais documentos nem indicação de sua existência. A lacuna consiste na ausência de modelos padronizados para o planejamento de contratações de TI.
q2801ext[C]	Sim	Não	A avaliação indica que o processo de seleção de fornecedores não está definido. A portaria apresentada não abrange etapas, responsabilidades ou artefatos relativos à fase de seleção. A evidência é insuficiente por tratar exclusivamente de gestão e fiscalização de contratos. A lacuna refere-se à falta de descrição ou normatização do processo de seleção de fornecedores de TI.
q2801ext[D]	Sim	Não	A avaliação indica que não são disponibilizados artefatos padronizados para a seleção de fornecedores. A documentação enviada não inclui minutas, checklists, editais ou critérios de julgamento. A evidência é insuficiente por não apresentar qualquer artefato dessa natureza. A lacuna consiste na ausência de instrumentos padronizados para a seleção de fornecedores de TI.
q2801ext[E]	Sim	Não	A avaliação indica que, embora a portaria mencione competências gerais de fiscalização, não há a estruturação de um processo de trabalho por etapas específico para contratos de TI. A evidência é insuficiente pois não demonstra fluxogramas, manuais ou etapas processuais detalhadas com artefatos resultantes para o contexto de TI. A lacuna é a falta de um processo de trabalho formalizado para a gestão e fiscalização de contratos de TI.

Questão	Resposta original	Resposta ajustada	Justificativa
q2801ext[F]	Sim	Não	A avaliação indica que não são disponibilizados artefatos padronizados para a gestão e fiscalização de contratos de TI. O documento limita-se a atribuir responsabilidades, sem apresentar modelos de planos de fiscalização, termos de recebimento ou relatórios de acompanhamento específicos. A evidência é insuficiente pela ausência de tais modelos ou documentos comprobatórios. A lacuna consiste na falta de artefatos padronizados de fiscalização voltados a TI.
q2801ext[G]	Sim	Não	A avaliação indica que a aderência normativa dos processos de trabalho de TI não pode ser verificada. A portaria cita leis gerais de licitações; contudo, a ausência de processos e artefatos específicos de TI impede a análise da aderência à norma para este objeto. A evidência é insuficiente por não demonstrar a aplicação da legislação em fluxos ou instrumentos práticos de TI. A lacuna reside na inexistência de processos de trabalho de TI para confrontar com a legislação.
q2802ext[A]	Sim	Não	A Equipe de Auditoria não identificou documentos que comprovem a aprovação formal do PCA pela alta administração. A captura de tela do PNCP não supre a necessidade de atos administrativos, atas ou portarias de aprovação. Ausência de ato administrativo, ata, resolução ou documento assinado pela alta administração.
q2802ext[B]	Sim	Não	A Equipe de Auditoria observa que a evidência apresentada limita-se ao resultado final, sem demonstrar as etapas de elaboração do plano. Não foram fornecidos registros, fluxos ou documentos que comprovem a participação das áreas internas. Ausência de evidência documental da participação dos setores relevantes no processo de elaboração.
q2802ext[C]	Sim	Não	A Equipe de Auditoria não identificou elementos que conectem o PCA aos demais instrumentos de planejamento institucional, tais como PPA, LDO ou plano estratégico. A evidência restringe-se aos dados disponibilizados no portal nacional, sem demonstrar o alinhamento ou integração com outros instrumentos. Ausência de comprovação documental da integração do PCA com o planejamento institucional.
q2802ext[D]	Sim	Não	A Equipe de Auditoria não encontrou evidências que demonstrem a correlação entre o PCA e a proposta orçamentária. Embora o portal exiba o valor total estimado, não há registro da fundamentação orçamentária decorrente deste plano. Ausência de documento, nota técnica ou memória de cálculo que vincule o PCA à proposta orçamentária.

Questão	Resposta original	Resposta ajustada	Justificativa
q2701	Adota em maior parte ou totalmente.	Não adota.	O Regimento Interno (Portaria RIOPREV/PRESI nº 590/2025) estabelece a estrutura organizacional e as competências funcionais da Gerência de Tecnologia da Informação e Comunicações (GERTIC), conforme verificado nas páginas 18 e 19. Contudo, o documento não apresenta os perfis profissionais desejados, como formação acadêmica, experiência profissional ou competências técnicas exigidas para os ocupantes dos cargos de gestão de TI. A evidência analisada é insuficiente por não conter a definição desses requisitos específicos para os gestores, diferenciando-se de competências atribuídas à unidade. A lacuna reside na ausência de descrições de cargo ou matrizes de competências individuais.

(Fonte: elaboração própria)